

Chain-of-Thought Prompting of Large Language Models for Discovering and Fixing Software Vulnerabilities

Yu Nong
Washington State University
yu.nong@wsu.edu

Mohammed Aldeen
Clemson University
mshujaa@g.clemson.edu

Long Cheng
Clemson University
lcheng2@clemson.edu

Hongxin Hu
University at Buffalo
hongxinh@buffalo.edu

Feng Chen
The University of Texas at Dallas
feng.chen@utdallas.edu

Haipeng Cai
Washington State University
haipeng.cai@wsu.edu

Abstract

Security vulnerabilities are increasingly prevalent in modern software and they are widely consequential to our society. Various approaches to defending against these vulnerabilities have been proposed, among which those leveraging deep learning (DL) avoid major barriers with other techniques hence attracting more attention in recent years. However, DL-based approaches face critical challenges including the lack of sizable and quality-labeled task-specific datasets and their inability to generalize well to unseen, real-world scenarios. Lately, large language models (LLMs) have demonstrated impressive potential in various domains by overcoming those challenges, especially through chain-of-thought (CoT) prompting. In this paper, we explore how to leverage LLMs and CoT to address three key software vulnerability analysis tasks: identifying a given type of vulnerabilities, discovering vulnerabilities of any type, and patching detected vulnerabilities. We instantiate the general CoT methodology in the context of these tasks through VSP, our unified, vulnerability-semantics-guided prompting approach, and conduct extensive experiments assessing VSP versus five baselines for the three tasks against three LLMs and two datasets. Results show substantial superiority of our CoT-inspired prompting (553.3%, 36.5%, and 30.8% higher F1 accuracy for vulnerability identification, discovery, and patching, respectively, on CVE datasets) over the baselines. Through in-depth case studies analyzing VSP failures, we also reveal current gaps in LLM/CoT for challenging vulnerability cases, while proposing and validating respective improvements.

1 Introduction

Software vulnerabilities are consequential [14], posing significant threats to security of the cyberspace: they often result in critical financial losses, service disruptions, and data breaches [19]. The costs associated with remediating these vulnerabilities (e.g., expenses for incident response and system repair) are also substantial [32]. Meanwhile, security vulnerabilities are pervasive in modern software: according to

the NVD statistics [33], there have been 22,378 vulnerabilities publicly reported so far within 2023 alone, and this number has been on a steady rise over the years. In fact, there are even more than reported since some are silently patched [66] many have not been discovered yet. On the other hand, it is difficult to avoid introducing vulnerabilities during software development and evolution [31]. Thus, it is crucial to defend against vulnerabilities through vulnerability detection and patching.

Various approaches to defensive software vulnerability analysis have been proposed, including those based on static/dynamic program analysis [5, 42], the mixture of both [60], and data-driven methods (especially machine/deep learning) [11, 64]. These techniques demonstrated respective merits while covering all the major kinds of defense tasks against vulnerabilities, including *identification* of given types of vulnerabilities [3] (e.g., memory leaks [13, 43], use-after-free [10, 57, 71, 79], double-free [10], XSS [73], and buffer overflow [26, 40, 67]), *discovery* of vulnerabilities of various types [9, 20, 22, 27, 30, 38, 44, 47, 53, 56, 68, 81, 86], and *patching* the detected vulnerabilities [12, 21, 24, 51, 65, 85].

However, these classes of techniques each face their major challenges. In particular, *purely static techniques* (e.g., [13, 38, 43]) suffer from the excessive imprecision of the underlying static analysis [60], causing high rates of false alarms which are a key practicality barrier [34]. In addition, they are subject to unsoundness due to the prevalent use of dynamic language constructs [44] in modern programs and limited scalability to large-scale codebases [42, 60]. *Purely dynamic* (e.g., [9, 27, 56]) and *hybrid* (e.g., [68]) techniques have their capabilities constrained by the coverage of existing program inputs, which is usually insufficient, hence missing potentially critical vulnerabilities (i.e., low recall [60]).

Data-driven approaches, especially those based on deep learning (DL), helped with overcoming those limitations [11]. Indeed, existing *DL-based techniques*, leveraging various neural network architectures (e.g., CNN [81], RNN/Transformer [20, 30], and GNN [53, 86]), have achieved notable successes [64]. Yet despite their merits in both detection [46, 47, 53] and repair [12, 21], they fall short of prac-

tical performance when applied to unseen, real-world programs [64] and stumble on the lack of sizable and quality training datasets [62, 63]. Most recent applications [61, 63] of 7 state-of-the-art DL-based techniques [11, 12, 20, 21, 30, 46, 86] show that they achieved no more than 16.43% F1 accuracy and 8.55% top-1 accuracy for vulnerability detection and repair, respectively, in replication settings; even after using the most advanced data-augmentation technique focused on these tasks [61] to augment the training sets with 15,000+ high-quality samples, those two numbers could only go up to 20.1% and 21.05%, respectively.

Lately, pre-trained large language models (LLMs) have demonstrated promising performance in assisting with a wide range of tasks, including those of software analysis [35, 36]. Especially, unlike fine-tuning [83] and prompt learning [50], prompting LLMs does not need sizable task-specific datasets, hence addressing the key pain point with the DL-based approaches. In particular, chain-of-thought (CoT) [75], a state-of-the-art prompting technique has shown excitingly potential in pushing up the performance of various LLMs. Through, a few step-by-step reasoning demonstrations provided to LLMs as exemplars during prompting, CoT elicits the same reasoning capabilities of the model toward correct answers with a much greater chance. While CoT has been explored in relevant tasks [17, 41, 82] and its core idea is simple, it remains unclear how it may be effectively instantiated and leveraged for software vulnerability analysis tasks. For instance, we experimented with exemplifying line-by-line code semantics description as the chain of thoughts, but only to no avail. On the other hand, using LLMs without reasoning-eliciting prompting (e.g., in the zero-shot setting) has not quite succeeded in vulnerability analysis [65, 80].

In this paper, we systematically explore defensive software vulnerability analysis by prompting LLMs, instantiating the general CoT methodology in the context of vulnerability identification, discovery, and patching tasks. Underlying these three tasks, we propose *vulnerability semantics guided prompting* (VSP), a unified CoT-inspired prompting strategy that maps *vulnerability semantics* (i.e., behaviors of a vulnerable program that make it vulnerable) to chains of thoughts. With full code semantics being represented by all conventional data and control flow dependencies [2] in a program, vulnerability semantics are represented by the subset of those dependencies that capture (i.e., account for) the vulnerable behaviors. Accordingly, VSP formulates the *data/control flow facts underlying vulnerability semantics* as the “thoughts” and *the corresponding flow paths* as the “chain” in CoT. On top of VSP as the unified approach, we further propose a specific prompting scheme for each individual task; but all these schemes are guided by vulnerability semantics.

We then conducted extensive experiments, examining the efficacy of VSP versus five baselines, including two variants of VSP, the full-code-semantics-based prompting strategy (i.e., naive instantiation of CoT), few-shot learning, and

standard prompting. With these six strategies against three LLMs and two datasets, we compare the different ways of directly leveraging or eliciting the (existing) knowledge of various LLMs for the three vulnerability analysis tasks. Our results show that, with just a few (20) exemplars, VSP outperformed the baseline approaches by substantial margins for any of the three tasks, especially on the much more challenging dataset. For instance, for *vulnerability identification*, our method achieved 65.29% F1 on a synthetic dataset and **58.48%** F1 on a real-world (CVE) dataset, versus the best (non-VSP) baseline achieving only 56.28% and **8.96%**, respectively, on GPT-3.5 [18]. For *vulnerability discovery*, VSP achieved 54.07% F1 on the synthetic dataset and **45.25%** F1 on the CVE dataset, versus the best baseline achieving 52.04% and **33.16%**, respectively, on Llama2 [69]. For *vulnerability patching*, these numbers are 97.65% and **20.00%** with VSP versus 96.47% and **15.29%** with the best baseline, also on GPT-3.5. VSP also helped discover **22** true zero-day CVE vulnerabilities (with 40.00% accuracy), versus the standard-prompting baseline found **9** (with 16.36% accuracy) only.

Moreover, we performed in-depth case studies to analyze the failures encountered by VSP, and identified four common root causes across the three tasks. For instance, for both the vulnerability identification and patching tasks, and underlying both the false positives and false negatives, the dominating failure cause is that the *code context is insufficient* in the code snippet fed to the LLMs (e.g., lacking information about a self-defined/external function called in the code). Another major root cause, which is also the primary one for vulnerability discovery failures, is that the *LLMs miss important control flow facts as part of the vulnerability semantics* during their reasoning. In contrast, missing key data flow facts is another main failure cause, but more of a problem for vulnerability discovery than for identifying or patching vulnerabilities. We further proposed improvements to overcome these failures per their causes, and show the efficacy of our recommendations (e.g., making up insufficient context via code comments).

To the best of our knowledge, our work is the first to systematically examine how to leverage prompting LLMs for all three representative tasks in defensive software vulnerability analysis. Through VSP, we also demonstrate a promising direction toward those tasks by guiding LLMs via vulnerability semantics hence eliciting LLM knowledge to reason about the most essential behaviors of a program that make it vulnerable. Our extensive experiments and discussions suggest this direction can push the effectiveness of software vulnerability analysis to a new height (over the best DL-based approaches achieved so far). We also contribute, via our failure case studies and recommended solutions, to future ways of improving vulnerability analysis using LLMs. All of the code and datasets for our study have been made available at [Figshare](#).

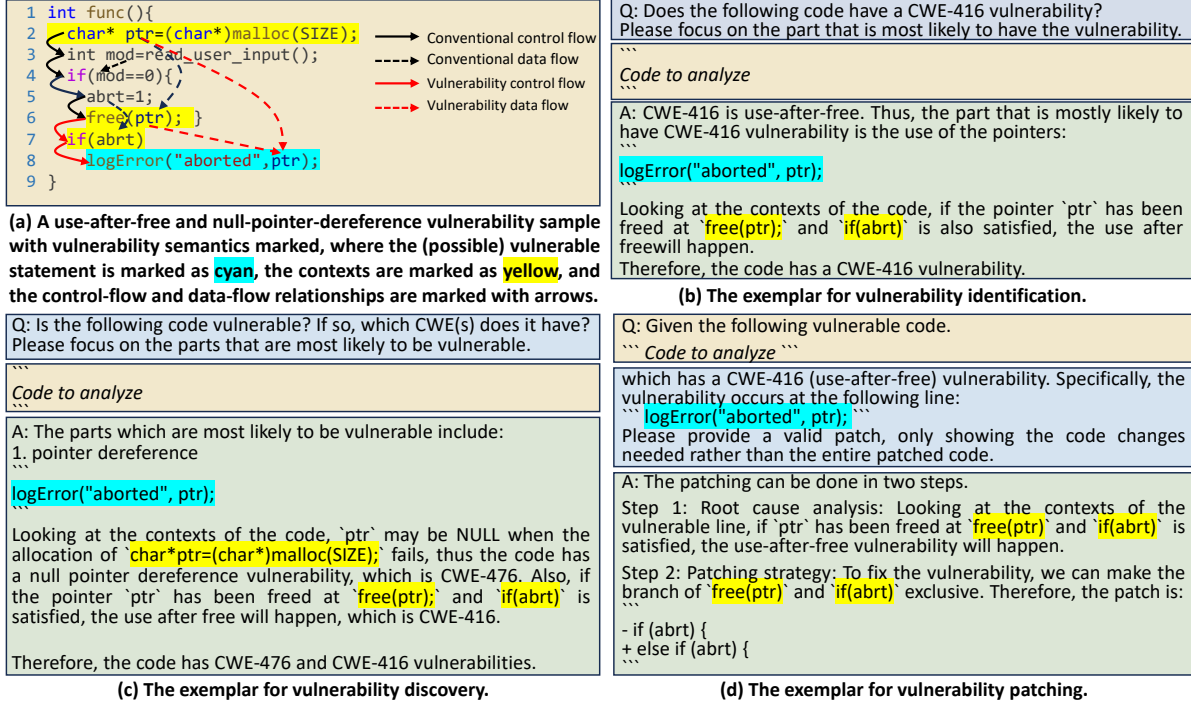


Figure 1: Illustrations of vulnerability semantics (a) and VSP exemplars for the three vulnerability analysis tasks (b,c,d).

2 Preliminary

Prompt Engineering. Recent LLMs such as GPT-3.5 [18] have shown promising performance with various tasks [15, 36, 49, 72, 76]. Users can directly ask LLMs to solve a problem via a natural language prompt like "whether the following code has a bug". Recent studies [58, 65] show that the prompting strategies significantly affect the performance of LLMs. To better exploit LLMs, *prompt engineering* [77] which seeks to optimize the prompts becomes a crucial topic. In prompt engineering, few-shot learning [8] can also improve performance with a few examples of desired inputs and outputs.

Chain-of-Thought Prompting. In prompting engineering with few-shot learning, chain-of-thought (CoT) [75] shows enormous potential on complex reasoning tasks by providing intermediate reasoning steps in the exemplars. It is effective on different tasks such as arithmetic reasoning and symbolic reasoning [75]. Moreover, zero-shot chain-of-thought is also effective in some tasks by directly showing the reasoning steps in the question without providing exemplars [37].

Vulnerability Analysis using LLMs. LLMs have been explored for vulnerability analysis tasks such as vulnerability finding [58], repair [65], and secure code generation [28]. However, these works use simple prompts and leave all the vulnerability analysis reasoning process to the LLMs. Since those tasks require complex reasoning steps such as vulnerability localization and comprehensive control/data flow analysis, simple prompts may not be effective enough. By its nature, CoT seems to fit well here, yet it remains unknown how to

best realize its potential for software vulnerability analysis, exploring which is thus the goal of this paper.

3 Methodology

In this section, we introduce our unified prompting strategy for vulnerability analysis. Then, we describe the three analysis tasks considered and the task-specific prompting schemes all based on the unified strategy. Note that our main goal is to explore how to effectively prompt LLMs for vulnerability analysis hence providing evidence about the potential/gaps and actionable insights to inform future technique development, rather than developing a deployable tool here. Finally, we describe the datasets and LLMs we use in this study, as well as the design and implementation of our experiments.

3.1 Vulnerability-Semantics-guided Prompting

Inspired by CoT [75], we propose *Vulnerability-Semantics-guided Prompting (VSP)*, which also instantiates the general CoT methodology. This strategy hones in on *vulnerability semantics*, the pivotal components of effective vulnerability analysis. This design is underpinned by two key insights: (1) While a program may encompass numerous lines of code, only a small fraction may be susceptible to vulnerabilities. Thus, centering on these critical segments, constituting the *vulnerability semantics*, empowers LLMs to conduct vulnerability analysis to the fullest extent; (2) Mainstream LLMs are based on Transformer [70], which is known to exhibit diminished performance when handling/generating extensive

text [62]. Therefore, concentrating on vulnerability semantics aids in curtailing the length of exemplars, prompts, and answers, mitigating potential distractions for the LLMs.

Vulnerability Semantics. Given that only a small proportion of code may cause vulnerabilities, locating the statements that are (possibly) vulnerable is crucial as these statements are the core of vulnerability semantics. However, such statements themselves cannot cause vulnerabilities without proper context. For a comprehensive vulnerability analysis, the contextual statements that have control and data-flow relationships that may involve *vulnerable behaviors* are also important [59, 60]. Therefore, we define vulnerability semantics as the behaviors of vulnerable statements and those of their relevant contextual statements. This avoids including all the code semantics and helps LLMs focus on the crucial parts.

Figure 1 (a) shows an example involving use-after-free and null-pointer-dereference vulnerabilities with vulnerability semantics marked. To understand the semantics, we first locate the statement that likely has the two vulnerabilities, which uses a pointer at line 8 marked in cyan. Then, we locate the statements that have data and control flow dependency relationships with line 8: lines 2 and 6 have the data-flow relationships that may cause a NULL pointer dereference and use-after-free vulnerabilities, as marked with red dashed arrows. Lines 6 and 7 have control-flow relationships that may cause the use-after-free vulnerability, as marked with the red arrows. Therefore, lines 2, 6, and 7 form the context, which are marked in yellow. Therefore, line 8 along with the context constitutes the vulnerability semantics.

Prompting Strategy. Guided by vulnerability semantics, we leverage CoT-based few-shot learning to achieve VSP. Each VSP prompt consists of two parts. The first part is the set of a few exemplars that provide examples of the reasoning steps for the model to perform few-shot learning. Specifically, each exemplar consists of a question for the task, a code sample, and the answer for the question which includes the reasoning steps. The reasoning steps in the answers focus on the vulnerability semantics discussed above. The second part is the testing sample we want the model to analyze. In the testing sample, we ask the question which has the same format as the questions in the exemplars. Then, we expect the LLMs to output the answer following the vulnerability-semantics-based reasoning steps in the exemplars.

The VSP strategy lays the bedrock of different vulnerability analysis tasks in our study. Figure 2 illustrates the overall design: We use VSP as the unified/common strategy under the detailed prompting scheme for each task. Note that we intend to examine the potential of VSP for each task—these tasks are orthogonal, and each task assumes what it needs to assume, rather than based on the output of the previous task. We do not aim to develop a holistic vulnerability analysis system (e.g., starting with identification followed by patching).

3.2 Tasks

In this work, we address three software vulnerability analysis tasks: (1) vulnerability **identification** (determining if a provided code sample has a specific type of vulnerability), (2) vulnerability **discovery** (discovering potential vulnerabilities in code samples without specifying their types), and (3) vulnerability **patching** (creating a patch based on a vulnerable sample and vulnerability type and location). These tasks span various levels of vulnerability analysis, representing the key steps in defenses against software vulnerabilities.

Next, we separately describe the goals, formulation, and detailed prompting schemes for the three tasks.

3.2.1 Task 1: Vulnerability Identification

Goal. The goal of vulnerability identification is to determine whether a given code sample has a specific type of vulnerability (e.g., CWE), as whether a vulnerability detector can find specific types of vulnerabilities determines its effectiveness.

Formulation. We formulate vulnerability identification as a binary classification task. In the LLM input prompt, we provide a code sample in terms of text and ask the model *whether the given text has a CWE-xxx vulnerability*, where *CWE-xxx* is the CWE ID of the vulnerability type.

Prompting. As discussed in Section 3.1, we provide the exemplars for vulnerability identification and the testing sample in each prompt. As Figure 1 (b) shows, for each exemplar, we ask the question for vulnerability identification: "*Q: Does the following code have a CWE-xxx vulnerability?*". Besides the question itself, we also request the model: "Please focus on the part that is most likely to have the vulnerability." This is to guide the model to focus on vulnerability semantics. Then, we provide the code to analyze. Each exemplar's answer part includes an explanation of the CWE ID's meaning for clarity. Then, we find the possible vulnerable statements based on the vulnerability type as well as the contexts of them based on the vulnerability control and data flow relationships. We analyze the conditions of the contexts and decide whether the code has a specific type of vulnerability. We finally provide the testing sample by asking the same question as in the exemplars to let the model output its response.

3.2.2 Task 2: Vulnerability Discovery

Goal. In this task, LLMs are asked to discover possible vulnerabilities without being provided with CWE IDs. This serves to evaluate their practical applicability. In real-world software vulnerability analysis, developers often lack prior knowledge of specific vulnerabilities in given code and their corresponding CWE IDs. Hence, vulnerability analysis techniques need to pinpoint potential vulnerabilities and classify their types.

Formulation. We formulate vulnerability discovery as a multi-class classification task. Given a code sample in the form of text, we ask the model whether the code has any vulnerability(ies), and if so, which CWE(s) the code has.

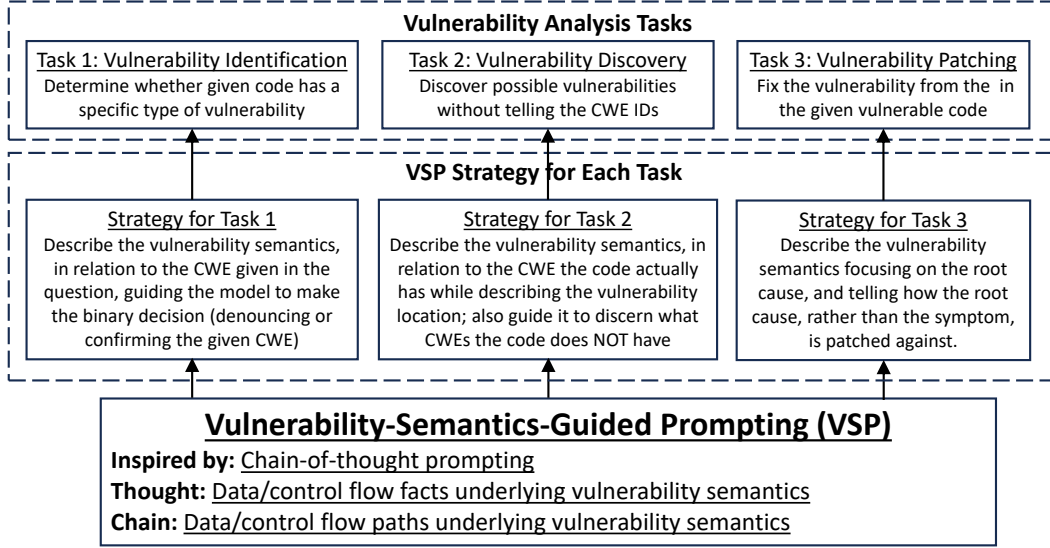


Figure 2: An overview of vulnerability-semantics-guided prompting for vulnerability analysis tasks.

Prompting. As Figure 1 (c) shows, in each exemplar, we ask the question for vulnerability discovery: "Q: Is the following code vulnerable? If so, which CWE(s) does it have? Please focus on the parts that are most likely to be vulnerable." Then, we provide the code sample. In the answer, we enumerate the types of statements that may be vulnerable and locate them within the code. For each potentially vulnerable statement, we identify the associated contexts based on the relevant vulnerability control and data flow relationships. Ultimately, we conduct an analysis of the vulnerability semantics to determine the presence of vulnerability(-ies) and, if any, their corresponding CWE(s). Subsequently, we present the test sample with the same question as posed in the exemplars, letting the model provide its response.

3.2.3 Task 3: Vulnerability Patching

Goal. The goal of this task is to eliminate the vulnerability from the code while preserving the code functionality. This is crucial because it addresses the security issues of the code and avoids possible attacks and damage to the systems.

Formulation. We formulate vulnerability patching as a text-to-text transformation task. Given a vulnerable sample in the form of text, we ask the model to generate a patch. We directly tell the model the vulnerable line and the respective CWE, which is common for bug/vulnerability patching [12, 21, 24]. With the vulnerable code sample, the vulnerable line, and the CWE ID, the model outputs the patch in terms of only the lines changed (rather than the entire patched sample).

Prompting. As Figure 1 (d) shows, in each exemplar, we ask the model to generate a patch for the given code: "Given the following vulnerable code: '<vulnerable code>' which has a CWE-xxx (<description of CWE>) vulnerability. Specifically, the vulnerability occurs at the following line: <vulnera-

ble line>. Please provide a valid patch, only showing the code changes needed rather than the entire patched code." In the answer, we analyze the *root cause* of the vulnerability based on its semantics. Then, we assess the *patching strategy* and identify a corrective action to fix the vulnerability via code edits. Finally, we provide a test sample with the same question as in the exemplars, letting the model give its response.

3.3 Datasets

In this study, we manually construct exemplars for CoT-based few-shot learning, targeting five most dangerous CWEs in C/C++ code [1]: (1) CWE-787 (out-of-bound write), (2) CWE-125 (out-of-bound read), (3) CWE-476 (NULL-pointer-dereference), (4) CWE-416 (use-after-free), and (5) CWE-190 (integer overflow). We focus on C/C++ because C/C++ vulnerabilities cover the dominant classes of vulnerabilities and they are the most vulnerable languages [60]. For each CWE, we provide four pairs of samples, each comprising a vulnerable and a corresponding patched sample. This results in a total of 20 pairs. The samples are inspired by the examples on the CWE report website [1]. We use the strategies described above to write the respective exemplars.

We evaluate the three tasks using two testing datasets. The first is a synthetic dataset known as SARD [7], containing a substantial number of vulnerable and respective non-vulnerable samples. The second is a real-world vulnerability dataset curated by Fan et al. [16], sourced from CVE reports [55], providing both vulnerable and respective patched code samples. We exclusively focus on samples pertaining to the five CWEs mentioned above. Considering the cost of commercial LLMs (e.g., GPT-3.5) and the time consumption, we only select 500 pairs of samples for each testing dataset. We use both datasets as we want to assess the difficulties of

Model	Version	#Param	#Max Tokens
GPT-3.5	gpt-3.5-turbo-16k	175B	16,385
Llama2	llama-2-7b-chat-hf	7B	4,096
Falcon	falcon-7b-instruct	7B	2,048

Table 1: LLMs we investigated.

analyzing simple/synthetic samples and complex/real-world samples with LLMs, helping us obtain more in-depth insights.

3.4 Models

Table 1 summarizes the three latest LLMs used in our study, including the model version, size, and token constraints. In particular, **GPT-3.5** [18] is a primary LLM from OpenAI which can understand and generate natural language and code. We chose GPT-3.5-Turbo over GPT-4 due to the latter’s high price. **Llama2** [69] is the latest LLM from Meta AI. We chose the `llama-2-7b-chat-hf` version due to the resource limitation of our machine. For the same reason, we chose the `falcon-7b-instruct` version of **Falcon** [88], an LLM from technology innovation institute. While these models are not the most advanced/capable in their families, our choices should not affect much what our study aims to achieve.

3.5 Baselines

In addition to VSP, we examine the following five baselines:

Standard Prompting. We ask the LLMs to address the tasks without providing any exemplars or guidance, aiming to assess their raw/original potential.

Standard Few-Shot Learning. For each exemplar, we only provide the final answer without any reasoning steps. This is to test whether the improvements (if any) are from the reasoning steps rather than the final answers in the exemplars.

Naive CoT-based Few-Shot Learning. Instead of focusing on the vulnerability semantics, we analyze the code line by line to address the tasks. This is to test whether the VSP strategy outperforms full semantics analysis.

Zero-Shot VSP Prompting. We do not provide the exemplars, but in the prompts, we provide steps for VSP-based vulnerability analysis. This is to test whether providing exemplars improves the model’s reasoning capabilities.

Other-type VSP Prompting. We ensure that the exemplars used do not overlap with any testing sample in terms of the CWE covered, for assessing whether LLMs’ reasoning capabilities elicited from the exemplars can be transferred across different vulnerability types.

3.6 Implementation

For GPT-3.5, we subscribe the APIs from OpenAI to process the input and generate the results. For Llama2 and Falcon, we download the models from HuggingFace [78] and use its APIs to conduct the experiments. We set the temperatures of the LLMs to 0 to reduce the randomness. We perform our

experiments on a workstation with an AMD Ryzen Threadripper Pro 5595WX (4.5GHz) CPU with 64 Cores, four Nvidia GeForce RTX A6000 GPU, and 512GB memory.

4 Task 1: Vulnerability Identification

4.1 Metrics

Since the task is formulated as a binary classification task, we evaluate the effectiveness in terms of recall, precision, and F1, which are standard metrics for binary classification tasks. We use an automatic script to check the outputs by some key phases (e.g., "the code has a CWE-xxx vulnerability") to determine the model predictions.

4.2 Results

Overall Performance. Table 2 shows the effectiveness of *VSP prompting* and the baselines against the vulnerability identification task in terms of F1, because F1 is the metric that represents the overall effectiveness of binary classification. We show the detailed numbers of recall, precision, and F1 for each CWE in Tables 9, 10, and 11 in Appendix. For all three LLMs, VSP prompting achieves the best F1 scores. On the SARD dataset, GPT-3.5, Llama2, and Falcon achieve 65.29%, 60.18%, and 51.25% F1, respectively. On the CVE dataset, GPT-3.5, Llama2, and Falcon achieve 58.48%, 44.80%, and 36.36% F1, respectively. We also notice that the F1 scores on the SARD dataset are higher than the ones on the CVE dataset. This is because the samples in SARD are synthetic which is generally simple while the samples in CVE are real-world and complex which makes the vulnerability identification more challenging. The high F1 scores indicate that VSP Prompting is practical for vulnerability identification.

Comparison to Standard Prompting. To show that VSP prompting is necessary and effective for vulnerability identification, we compare it with simple standard prompting on LLMs. Table 2 shows the F1 scores of standard prompting on the same datasets. We notice that the F1 scores of standard prompting are much lower than the ones of VSP prompting on all the settings: with standard prompting, GPT-3.5, Llama2, and Falcon achieve 56.28%, 54.94%, and 0.00% on the SARD dataset, and 3.59%, 35.10%, 4.69% on the CVE dataset. This indicates that the reasoning steps in VSP prompting help LLMs outperform their own reasoning steps for vulnerability identification. We also notice that the improvements of VSP prompting are higher on the CVE dataset (e.g., 58.48% to 3.59% for GPT-3.5). This further indicates the necessity of VSP prompting for real-world vulnerability identification.

Comparison to Standard Few-shot Learning. Table 2 shows the F1 scores of standard few-shot learning for vulnerability identification. We notice that it has poor effectiveness compared with VSP prompting. With standard few-shot learning, GPT-3.5, Llama2, and Falcon only achieve 34.01%, 56.71%, and 50.15% F1 scores on the SARD dataset, and 0.80%, 34.08%, and 30.45% F1 scores on the CVE dataset.

Model	Dataset	Strategy	F1	Model	Dataset	Strategy	F1	Model	Dataset	Strategy	F1
GPT-3.5	SARD	Standard Prompting	56.28%	Llama2	SARD	Standard Prompting	54.95%	Falcon	SARD	Standard Prompting	0.00%
		Standard Few-Shot	34.01%			Standard Few-Shot	56.71%			Standard Few-Shot	50.15%
		Naive CoT Learning	15.17%			Naive CoT Learning	47.64%			Naive CoT Learning	22.69%
		Zero-Shot VSP	55.78%			Zero-Shot VSP	53.25%			Zero-Shot VSP	1.19%
		VSP Prompting	65.29%			VSP Prompting	60.18%			VSP Prompting	51.25%
		Other-Type VSP	65.06%			Other-Type VSP	59.33%			Other-Type VSP	50.46%
	CVE	Standard Prompting	3.59%		CVE	Standard Prompting	35.10%		CVE	Standard Prompting	4.69%
		Standard Few-Shot	0.80%			Standard Few-Shot	34.08%			Standard Few-Shot	30.45%
		Naive CoT Learning	8.96%			Naive CoT Learning	22.72%			Naive CoT Learning	23.40%
		Zero-Shot VSP	4.62%			Zero-Shot VSP	40.15%			Zero-Shot VSP	23.91%
		VSP Prompting	58.48%			VSP Prompting	44.80%			VSP Prompting	36.36%
		Other-Type VSP	56.34%			Other-Type VSP	44.02%			Other-Type VSP	35.41%

Table 2: Vulnerability Identification Results in terms of F1.

This indicates that while providing the same exemplars, the LLMs still cannot achieve the effectiveness of VSP prompting without providing the vulnerability-semantics-guided reasoning steps. This indicates the importance of the vulnerability semantics for vulnerability identification.

Comparison to Naive CoT Learning. To show that our vulnerability-semantic-guided design in VSP prompting is important, we compare it with a naive chain-of-thought design which analyzes the code line by line to identify the vulnerability. As Table 2 shows, with naive CoT learning, GPT-3.5, Llama2, and Falcon only achieve 15.17%, 47.64%, and 22.69% F1 scores on the SARD dataset, and 8.96%, 22.72%, and 23.40% F1 scores on the CVE dataset. These numbers are much lower than the ones for VSP prompting. This indicates the importance of vulnerability semantics. Because only a small proportion of code is indeed relevant to vulnerabilities, the line-by-line reasoning involve much information not relevant to vulnerabilities which distracts the LLMs.

Comparison to Zero-Shot VSP. To show the necessity of exemplars, we test zero-shot VSP, which tells the VSP-based reasoning steps in the prompt but does not provide exemplars. We tell the LLMs to "focus on the parts that are most likely to be vulnerable and their contexts based on control-flow and data-flow relationships". As Table 2 shows, with zero-shot VSP, GPT-3.5, Llama2, and Falcon only achieve 55.78%, 53.25%, and 1.19% F1 scores on the SARD dataset, and 4.62%, 40.15%, and 23.91% F1 scores on the CVE dataset. These numbers are much lower than the ones for VSP prompting, indicating the importance of exemplars.

Transferability of VSP Prompting. In the experiments above, the CWEs of the testing samples are consistent with the exemplars. In this experiment, we test whether the benefits of VSP Prompting still exist when the CWEs of exemplars are different from the testing samples. We write exemplars with different CWEs (e.g., CWE-20, CWE-78, CWE-269, CWE-369, and CWE-798) but keep the VSP strategies. As Table 2 rows "Other-Type VSP" shows, GPT-3.5, Llama2, and Falcon achieve 65.06%, 59.33%, and 50.46% F1 scores on the SARD dataset, and 56.34%, 44.02%, and 35.41% F1 scores on the CVE dataset. These numbers are comparable to the ones in VSP prompting. This indicates that VSP prompting

Failure Reason	CVE		SARD	
	FN	FP	FN	FP
Insufficient contexts	35%	42%	8%	7%
Oblivion of CWE	19%	17%	17%	9%
Incomplete control flow analysis	18%	21%	28%	40%
Incomplete data flow analysis	28%	20%	47%	44%

Table 3: Failure Reasons for Vulnerability Identification.

is transferable for vulnerability identification: the LLMs are able to learn the reasoning steps while the CWEs are different.

4.3 Failure Case Studies

Although VSP prompting outperforms all the other baselines for vulnerability identification, we conduct case studies for the failure cases. Since the case studies are time-consuming, we only do case studies on the GPT-3.5 results. We manually inspect the false negative and false positive cases on the CVE and SARD datasets separately. For each case study, we follow the error analysis in [29] and randomly select 100 test samples with wrong predictions, and manually inspect the reasons for the failures. Based on the inspection, we categorize the reasons into 4 categories.

Table 3 shows the statistics of the four failure reasons. The first category is insufficient contexts. Because most LLMs have limitations on the number of tokens processed, it is not possible to directly input the whole project into LLMs [65]. Therefore, in this study, we only input the vulnerable function itself to the LLMs. However, many vulnerabilities are inter-procedural where the vulnerability cannot be comprehensively analyzed without scanning all the code in the project. We notice that this is common on the CVE dataset, with 35% on the FN cases and 42% on the FP cases. This is because the samples from CVE are from real-world projects and they usually have many functions and files, which make the analysis challenging. In comparison, the proportions on the SARD dataset are much lower, with 8% on the FN cases and 7% on the FP cases. This is because the synthetic samples from SARD are relatively simple. Most of the samples are standalone and thus the vulnerability identification is much easier.

The second category is the oblivion of CWE. We notice that in some failure cases, GPT-3.5 "forgets" the CWE type it needs to identify. For example, we ask the model to identify a CWE-787 out-of-bound vulnerability in the question, but

the model identifies the NULL pointer dereference vulnerability in its reasoning steps. A possible reason is that the Transformer architecture, where LLMs are based, would have performance degradation when the text to be processed is too long [62]. As Table 3 shows, the proportions of oblivion of CWE are 19% and 17% for the FN cases and FP cases from the CVE dataset respectively, and 17% and 9% for the FN cases and FP cases from the SARD dataset respectively, indicating that this issue is widespread.

The third category is incomplete control flow analysis. In some failure cases, GPT-3.5 is not able to do a comprehensive control flow analysis. For example, when identifying a CWE-476 NULL-pointer-dereference vulnerability, the model may still affirm that the dereference of a pointer is possible to be NULL, while the NULL pointer checking has been done before the dereference. This indicates that while we have provided the control-flow analysis reasoning steps in the exemplars, they still cannot do complex and comprehensive analysis like traditional static analysis techniques do. As Table 3 shows, the proportions of incomplete control flow analysis are 18% and 21% for the FN cases and FP cases from CVE respectively, and 28% and 40% for the FN cases and FP cases from SARD respectively. The higher proportions on SARD indicate that, while the samples are simple, the LLMs still have limitations on doing complete control flow analysis.

The fourth category is incomplete data flow analysis. In some failure cases, GPT-3.5 is not able to do comprehensive data flow analysis. For example, when identifying a CWE-787 out-of-bound vulnerability, the model may still affirm that a buffer write may be beyond the boundary of the buffer while the buffer has reserved enough space for the buffer write. This indicates, again, that while LLMs are capable to some extent, they still cannot do complex and comprehensive data flow analysis. As Table 3 shows, the proportions of incomplete data flow analysis are 28% and 20% for the FN cases and FP cases from CVE respectively, and 47% and 44% for the FN cases and FP cases from SARD respectively.

5 Task 2: Vulnerability Discovery

5.1 Metrics

Since the task is formulated as a multi-class classification task where the classes are the CWE IDs of the vulnerabilities, we first evaluate the recall, precision, and F1 on each of the classes and then compute the overall effectiveness using macro-averaging and micro-averaging [4]. We use an automatic script to check the outputs of the models like what we do in Task 1. Once the predicted classes involve the ground-truth one, the prediction is positive, otherwise negative.

5.2 Results

Overall Performance. Table 4 shows the effectiveness of VSP prompting and the baselines against the vulnerability discovery task in terms of macro-averaged and micro-averaged

F1. We show detailed recall, precision, and F1 for each CWE in Tables 12, 13, and 14 in Appendix. We notice that VSP prompting achieves the best overall effectiveness in most of the cases. On the SARD dataset, GPT-3.5, Llama2, and Falcon achieve 55.83%, 54.07%, and 46.01% macro-averaged F1 with VSP prompting, respectively, and the numbers of micro-averaged F1 are 60.21%, 60.92%, and 46.83% respectively. On the CVE dataset, GPT-3.5, Llama2, and Falcon achieve 36.34%, 45.25%, and 46.01% macro-averaged F1 with VSP prompting, respectively, and the numbers of micro-averaged F1 are 36.89%, 48.35%, and 28.11% respectively. This indicates that our VSP prompting strategy is able to improve the LLMs for vulnerability discovery significantly.

Comparison to Standard Prompting. We compare our VSP prompting to standard prompting. As Table 4 shows, on the SARD dataset, GPT-3.5, Llama2, and Falcon achieve 54.02%, 16.22%, and 0.17% macro-averaged F1 with standard prompting, respectively, and the numbers for micro-averaged F1 are 51.50%, 48.27%, and 0.39% respectively. On the CVE dataset, GPT-3.5, Llama2, and Falcon achieve 3.28%, 17.09%, and 0.69% macro-averaged F1 with standard prompting, respectively, and the numbers for micro-averaged F1 are 6.70%, 35.39%, and 1.22% respectively. These numbers are much less than the ones for VSP prompting, indicating that VSP prompting helps LLMs with vulnerability discovery.

Comparison to Standard Few-Shot Learning. As Table 4 shows, on SARD, GPT-3.5, Llama2, and Falcon achieve 55.19%, 21.48%, and 13.78% macro-averaged F1 with standard few-shot learning, respectively, and the numbers for micro-averaged F1 are 46.83%, 40.91%, and 12.46% respectively. On CVE, GPT-3.5, Llama2, and Falcon achieve 16.21%, 24.92%, and 13.78% macro-averaged F1 with standard prompting, respectively, and the numbers for micro-averaged F1 are 11.60%, 28.79%, and 15.06% respectively. We notice that, while standard few-shot learning has improvements compared to standard prompting in some cases (e.g., on CVE with the GPT-3.5 model), it is not comparable to the VSP prompting. This indicates that the reasoning steps in our VSP prompting are crucial for vulnerability discovery.

Comparison to Naive CoT Learning. As Table 4 shows, on SARD, GPT-3.5, Llama2, and Falcon achieve 41.13%, 52.04%, and 18.81% macro-averaged F1 with naive CoT learning, respectively, and the numbers for micro-averaged F1 are 34.08%, 59.47%, and 22.90% respectively. On CVE, GPT-3.5, Llama2, and Falcon achieve 14.75%, 33.16%, and 12.54% macro-averaged F1 with standard prompting, respectively, and the numbers for micro-averaged F1 are 14.86%, 39.17%, and 11.52% respectively. While naive CoT learning improves LLMs for vulnerability discovery compared to standard prompting in some cases (e.g., on CVE with GPT-3.5), the effectiveness is still lower than one from VSP prompting. This indicates that VSP prompting which focuses on vulnerability semantics is effective for vulnerability discovery.

Comparison to Zero-Shot VSP. For zero-shot VFP, we again tell the model to "focus on the parts that are most likely to be vulnerable and its contexts based on control-flow and data-flow relationships". As Table 4 shows, on SARD, GPT-3.5, Llama2, and Falcon achieve 48.49%, 15.58%, and 0.63% macro-averaged F1 with zero-shot VSP, respectively, and the numbers for micro-averaged F1 are 47.91%, 47.56%, and 0.79% respectively. On CVE, GPT-3.5, Llama2, and Falcon achieve 16.81%, 9.96%, and 0.00% macro-averaged F1 with standard prompting, respectively, and the numbers for micro-averaged F1 are 22.07%, 23.97%, and 0.00% respectively. This indicates that, without exemplars in the prompt, the LLMs cannot perform well for vulnerability discovery.

Transferability of VSP Prompting. We again test the transferability of VSP Prompting with the exemplars where the CWEs are different from the testing samples. The rows "Other-type VSP" in Table 4 show the F1 scores. We notice that on the GPT-3.5 model, the benefits still exist. It achieves 57.33% macro-averaged F1 and 62.19% micro-averaged F1 on SARD, as well as 19.58% macro-averaged F1 and 30.28% micro-averaged F1 on CVE. However, on the Llama2 and Falcon models, the benefits do not exist. On SARD, Llama2 and Falcon only achieve 29.54% and 4.28% macro-averaged F1, and the numbers for micro-averaged F1 are 48.44% and 8.13%. On CVE, Llama2 and Falcon only achieve 9.20% and 1.15% macro-averaged F1, and the numbers for micro-averaged F1 are 23.83% and 3.19%. A possible reason is that we only use the lite versions with 7B parameters for Llama2 and Falcon because of resource limitations. In comparison, we use the full version of GPT-3.5-Turbo with 175B parameters because it provides online API service. This indicates that the capability of LLMs impacts the effectiveness of the transferability of VSP prompting for vulnerability discovery.

5.3 Failure Case Studies

We again do failure case studies for vulnerability discovery. To be consistent with task 1, we still do case studies on the GPT-3.5 results. We manually inspect the false negative and false positive cases on the CVE and SARD datasets separately and we inspect 100 testing samples for each case study.

By inspecting the failure cases, we still categorize the failure reasons into the same four categories. Table 5 shows the statistics. Similar to the results in task 1, we notice that the reason insufficient context is much more common on the CVE dataset, with 21% in the false negative cases and 38% in the false positive cases. In comparison, on the SARD dataset, the numbers are 2% and 4%. Again, this is caused by the complex structures of the real-world samples from the CVE dataset.

We notice that the oblivion of CWE is still common in vulnerability discovery, with 14% and 14% proportions on the false negative and false positive cases against the CVE dataset, and with 11% and 4% proportions on the false negative and false positive cases against the SARD dataset. While the LLM needs to decide the CWE by itself in this task, it still "forgets"

Model	Dataset	Strategy	Macro avg	Micro avg
GPT-3.5	SARD	Standard Prompt	54.02%	51.50%
		Standard Few-shot	55.19%	46.83%
		Naïve CoT Learning	41.13%	34.08%
		Zero-Shot VSP	48.49%	47.91%
		VSP Prompting	55.83%	60.21%
		Other-Type VSP	57.33%	62.19%
	CVE	Standard Prompt	3.28%	6.70%
		Standard Few-shot	16.21%	11.60%
		Naïve CoT Learning	14.75%	14.86%
		Zero-Shot VSP	16.81%	22.07%
		VSP Prompting	36.34%	36.89%
		Other-Type VSP	19.58%	30.28%
Llama2	SARD	Standard Prompt	16.22%	48.27%
		Standard Few-shot	21.48%	40.91%
		Naïve CoT Learning	52.04%	59.47%
		Zero-Shot VSP	15.58%	47.56%
		VSP Prompting	54.07%	60.92%
		Other-Type VSP	29.54%	48.44%
	CVE	Standard Prompt	17.09%	35.39%
		Standard Few-shot	24.92%	28.79%
		Naïve CoT Learning	33.16%	39.17%
		Zero-Shot VSP	9.96%	23.97%
		VSP Prompting	45.25%	48.35%
		Other-Type VSP	9.20%	23.83%
Falcon	SARD	Standard Prompt	0.17%	0.39%
		Standard Few-shot	13.78%	12.46%
		Naïve CoT Learning	18.81%	22.90%
		Zero-Shot VSP	0.63%	0.79%
		VSP Prompting	46.01%	46.83%
		Other-Type VSP	4.28%	8.13%
	CVE	Standard Prompt	0.69%	1.22%
		Standard Few-shot	13.77%	15.06%
		Naïve CoT Learning	12.54%	11.52%
		Zero-Shot VSP	0.00%	23.97%
		VSP Prompting	29.61%	28.11%
		Other-Type VSP	1.15%	3.19%

Table 4: Vulnerability Discovery Results in terms of F1.

Failure Reason	CVE		SARD	
	FN	FP	FN	FP
Insufficient contexts	21%	38%	2%	4%
Oblivion of CWE	14%	14%	11%	4%
Incomplete control flow analysis	39%	34%	57%	59%
Incomplete data flow analysis	26%	21%	31%	33%

Table 5: Failure Reasons for Vulnerability Discovery

the CWE it is analyzing in some cases. For example, in some cases, the model decides to analyze the issues buffer write, and then in that paragraph, the model starts to analyze NULL pointer dereference. This indicates that the current LLMs still have limitations on complex and long logical analysis.

We also notice that incomplete data flow and control flow analysis are still common in the vulnerability discovery task, with 21%-59% proportions, while it is more common on the SARD dataset. This again indicates that while LLMs have the capability to understand code semantics and do control flow and data flow analysis to some extent, it is still a challenge for LLMs to do complex and comprehensive code analysis.

6 Task 3: Vulnerability Patching

6.1 Metrics

In this task, the LLMs are asked to generate a patch that tells what lines are modified/added/removed with the format of the

diff command outputs. However, the code style of the generated patch may be different from the ground-truth patches. Therefore, to evaluate the correctness of the generated patches, we manually check each generated patch. If the code patched by the generated patch has completely the same behavior as the one patched by the ground-truth patch (i.e., semantically equivalent), we mark the patch as correct. Therefore, we use accuracy, the proportion of correct patches in all the generated patches, as the metric to evaluate vulnerability patching.

Since SARD and CVE only provide vulnerable and patched code, manual labeling of vulnerable locations is necessary, due to potential disparities between the locations of vulnerability and patching, as illustrated in Figure 1 (d). Given the time-intensive nature of this process, we restrict our evaluation to samples involving single-line edits from both SARD and CVE. This yields a final selection of 170 samples from SARD and 85 from CVE. Additionally, as LLMs possess prior knowledge of the CWE and the vulnerable location when tasked with patching, we exclude the naive CoT learning baseline from this task.

6.2 Results

Overall Performance. Table 6 shows the effectiveness of VSP prompting and the baselines against the vulnerability patching task in terms of accuracy. The detailed accuracy of each CWE is shown in Table 15 in Appendix. On the SARD dataset, GPT-3.5 and Llama2 achieve 97.65% and 20.59% accuracy, respectively. On the CVE dataset, GPT-3.5 and Llama2 achieve 20.00% and 17.65%. GPT-3.5 achieves high accuracy on the SARD dataset because the patching patterns are very simple. In contrast, all the LLMs achieve relatively low accuracy on CVE, because of the complexity of the real-world samples. Falcon completely fails on this task. The reason is that Falcon can process up to 2,048 tokens, which is nearly equivalent to the size of the testing samples. This limited token capacity left little room for the inclusion of the vulnerable code to patch. This indicates the necessity to use a capable LLM to do vulnerability patching, as indicated in other studies [65, 80]. Nevertheless, the improvements on GPT-3.5 and Llama2 from VSP prompting still indicate its effectiveness for vulnerability patching.

Comparison to Standard Prompting. As shown in Table 6, standard prompting has poor accuracy. On SARD, GPT-3.5 and Llama2 achieve 65.88% and 12.35% accuracy. On CVE, GPT-3.5 and Llama2 achieve 8.24% and 2.35% accuracy. This indicates that vulnerability patching is challenging for LLMs without prompting engineering.

Comparison to Standard Few-Shot Learning. As shown in Table 6, standard few-shot learning achieves relatively high accuracy but the accuracy is still lower than the one achieved by VSP prompting. On the SARD dataset, GPT-3.5 and Llama2 achieve 96.47% and 8.82% accuracy, respectively. On the CVE dataset, GPT-3.5 and Llama2 achieve 15.29% and 12.94% accuracy, respectively. Based on our observations

on other baselines, we notice that, without few-shot learning or VSP prompting, the LLMs may output the whole patched code sample even if we explicitly say "only showing the code changes needed rather than the entire patched code". The long output may distract the LLMs and make the patch incorrect. In comparison, the exemplars in the standard few-shot learning and VSP prompting help standardize the format of the patches, thus improving the overall accuracy. This indicates the importance of exemplars for vulnerability patching.

Comparison to Zero-Shot VSP. To evaluate the zero-shot VSP prompting strategy, we tell the LLMs to generate patches step by step with the following prompt: "Step 1. Root cause analysis - analyze the root cause based on the given vulnerable line and the contexts with control flow and data flow analysis; Step 2. Patching Strategy - find a patching strategy which can eliminate the vulnerability based on the root cause analysis." This prompt describes the reasoning steps of VSP prompting. However, as Table 6 shows, zero-shot VSP has much worse accuracy compared to VSP prompting. On the SARD dataset, GPT-3.5 and Llama2 achieve 45.29% and 16.47% accuracy, respectively. On the CVE dataset, GPT-3.5 and Llama2 achieve 4.71% and 8.24% accuracy, respectively. Because of the complexity of the reasoning steps for vulnerability patching, it is difficult for LLMs to understand the reasoning steps without exemplars. This indicates the importance of exemplars for vulnerability patching.

Transferability of VSP Prompting. We use exemplars that have different CWEs to the testing samples to do the evaluation. As Table 6 row "Other-Type VSP" shows, the accuracy is much less than the one achieved by VSP prompting. On the SARD dataset, GPT-3.5 and Llama2 achieve 90.59% and 10.59% accuracy, respectively. On the CVE dataset, GPT-3.5 and Llama2 achieve 5.88% and 7.06% accuracy, respectively. One possible reason is that vulnerability patching is more complex than vulnerability identification and vulnerability discovery. Each CWE has different patching strategies which are difficult to transfer to another CWE.

6.3 Failure Case Studies

We again perform case studies related to instances where patching the vulnerability did not yield successful results. As Table 7 shows, similar to observations in the previous tasks, the insufficient context caused failures are remarkably prevalent in the CVE dataset (accounting for 44.26% of the cases), because of the complex structures of real-world projects.

The issue of oblivion of CWE is substantial within the CVE dataset, comprising 19.67% of cases. This issue occurs when the model, even after identifying the vulnerable lines, forgets the specific CWE it needs to address during the patching process. Again, this lapse in memory is partially due to the incapability of LLMs for long text.

Incomplete control and data flow analysis accounts for 21.31% and 14.75% of the failure cases on the CVE dataset, respectively. This is caused by the model's inability to per-

Model	Dataset	Strategy	Accuracy	Model	Dataset	Strategy	Accuracy	Model	Dataset	Strategy	Accuracy
GPT-3.5	SARD	Standard Prompting	65.88%	Llama2	SARD	Standard Prompting	12.35%	Falcon	SARD	Standard Prompting	0.00%
		Standard Few-Shot	96.47%			Standard Few-Shot	8.82%			Standard Few-Shot	0.00%
		Zero-Shot VSP	45.29%			Zero-Shot VSP	16.47%			Zero-Shot VSP	0.00%
		VSP Prompting	97.65%			VSP Prompting	20.59%			VSP Prompting	0.00%
		Other-Type VSP	90.59%			Other-Type VSP	10.59%			Other-Type VSP	0.00%
	CVE	Standard Prompting	8.24%		CVE	Standard Prompting	2.35%		CVE	Standard Prompting	0.00%
		Standard Few-Shot	15.29%			Standard Few-Shot	12.94%			Standard Few-Shot	0.00%
		Zero-Shot VSP	4.71%			Zero-Shot VSP	8.24%			Zero-Shot VSP	0.00%
		VSP Prompting	20.00%			VSP Prompting	17.65%			VSP Prompting	0.00%
		Other-Type VSP	5.88%			Other-Type VSP	7.06%			Other-Type VSP	0.00%

Table 6: Vulnerability patching results in terms of accuracy.

Failure Reason	CVE	SARD
Insufficient contexts	44.26%	0.00%
Oblivion of CWE	19.67%	0.00%
Incomplete control flow analysis	21.31%	0.00%
Incomplete data flow analysis	14.75%	100.00%

Table 7: Failure Reasons for Vulnerability Patching

<pre> 1 key_ref_t keyring_search(key_ref_t keyring, 2 struct key_type *type, const char *description){ 3 struct keyring_search_context ctx = { 4 5 .match_data = type->match, 6 7 }; 8 key_ref_t key; 9 int ret; 10 if (!ctx.match_data.cmp) 11 return ERR_PTR(-ENOKEY); 12 13} </pre>	Answer with Standard prompting: No, the given code does not have a CWE-476 vulnerability. CWE-476 refers to NULL Pointer Dereference, which occurs when a program attempts to use a pointer that has a null value. In the given code, there are checks in place to ensure that the pointers are not null before using it. If it is null, the code returns an error pointer instead of dereferencing the null pointer.
	Answer with VSFP prompt: A: CWE-476 is NULL pointer dereference. Thus, the part that is mostly likely to have CWE-476 vulnerability is the dereference of pointers: <pre> ''' if (!ctx.match_data.cmp)''' </pre> Looking at the contexts of the code, there is no guarantee that the pointers `ctx.match_data` is not NULL. Therefore, the code has a CWE-476 vulnerability.

Figure 3: An example of GPT-3.5 identifying a CWE-476 vulnerability with VSP but not with standard prompting.

form a comprehensive analysis for all possible execution paths. In the case of SARD, all the failure cases are related to data flow. Therefore, even with synthetic data, the model still faces some challenges in performing comprehensive data flow analysis in handling vulnerability patching.

7 Discussion

In this section, we further explore VSP’s potential by examining its help with discovering zero-days using LLMs. We also discuss the rationales behind VSP’s merits, as well as its limitations and improvement strategies. Finally, we compare VSP with recent peer approaches to vulnerability analysis.

7.1 Zero-Day Vulnerability Discovery

We evaluate VSP’s ability to detect recent zero-days, we pick a legacy LLM "GPT-3.5-Turbo-0301", frozen as of March 1st, 2023, without subsequent updates. We then collect 55 vulnerability samples from 19 critical software projects (e.g., Linux kernel) reported post-March 1st, 2023, from the CVE/NVD database [55]. Employing our VSP prompting strategy, the model correctly discovers 22 true-positive vulnerabilities at 40.00% accuracy. Without VSP, only 9 vulnerabilities are detected accurately, resulting in a mere 16.36% accuracy. Table 16 in the Appendix shows the detailed list of these vulnerabilities. This demonstrates the potential of our VSP strategy in aiding LLMs to uncover zero-day vulnerabilities.

7.2 Why VSP Works

The main reason that VSP improves LLMs’ vulnerability analysis effectiveness is that it makes LLMs focus on the parts that are most important for understanding vulnerabilities, which are vulnerability semantics in this work. Figure 3 shows an example that GPT-3.5 correctly identifies a CWE-476 vulnerability with VSP but fails with standard prompting. With standard prompting, GPT-3.5 just simply scans the code and notices that there are checks to ensure the pointers are not NULL, thus it predicts the code as non-vulnerable. However, it does not attend to the pointer dereference and the contexts for further analysis. Indeed, while the check at line 10 ensures that `ctx.match_data.cmp` is not NULL, it does not ensure that `ctx.match_data` is not NULL. Without focusing on that part of the code, it is easy to ignore this vulnerability. In contrast, with VSP, GPT-3.5 focuses on that part of the code and notices the dereference of pointer `ctx.match_data` may be NULL. In this case, the model correctly identifies the vulnerability. This indicates that focusing on vulnerability semantics is the main reason why VSP works better.

Another reason for VSP’s greater effectiveness is that it eliminates the irrelevant information that may distract the LLMs in the reasoning steps. This can be seen from our results on naive CoT learning underperforming VSP. With naive CoT learning, the code is analyzed line by line, no matter whether the lines are relevant to vulnerabilities, causing distractions hence diluting the core reasoning needed.

To further affirm the second reason, we conduct an experiment on vulnerability discovery. In the exemplars, we reason

A: The parts which are most likely to be vulnerable include:

1. buffer write:
There is no buffer write in the code, thus there is no risk of buffer write issues.
2. buffer read:
There is no buffer read in the code, thus there is no risk of buffer read issues.
3. integer computation and assignment:
There is no integer computation and assignment. Thus, there is no risk of integer overflow vulnerability.
4. pointer dereference
...

```
logError("aborted", ptr);
```

Looking at the contexts of the code, 'ptr' may be NULL when the allocation of `char*ptr=(char*)malloc(SIZE);` fails, thus the code has a null pointer dereference vulnerability, which is CWE-476. Also, if the pointer 'ptr' has been freed at `free(ptr);` and `if(abrt)` is satisfied, the use after free will happen, which is CWE-416.

Therefore, the code has CWE-476 and CWE-416 vulnerabilities.

Figure 4: The exemplar corresponding to Figure 1 (c) involving unnecessary text (marked as gray) in the reasoning.

about not only vulnerabilities specific to the sample but also other, common types of vulnerabilities. Figure 4 illustrates an instance with extraneous text related to Figure 1 (c). Including this unnecessary information reduces GPT-3.5’s micro-averaged F1 from 36.34% to 26.37%, and the macro-averaged F1 from 36.89% to 17.02% on the CVE dataset. This underscores the importance of eliminating irrelevant details in the reasoning process for VSP to attain good effectiveness.

7.3 Failure Causes and Recommendations

7.3.1 Insufficient Contexts

We notice that it is common for LLMs to fail on real-world samples because of insufficient contexts. Because real-world projects are usually large and involve many functions/files, many vulnerabilities are inter-procedural. This makes the vulnerability analysis difficult if we only provide a single function. However, given that LLMs can only process a limited number of tokens at a time (e.g., 16K for GPT-3.5), it is not likely to input the whole project into an LLM for analysis.

Therefore, a possible solution for this issue is to provide the context information in the code (e.g., by adding code comments). For example, when an external function is called in the function analyzed, we can add a comment telling what the external function does and what safety guarantees are done or not done in the function. Figure 5 in Appendix shows an example of adding comments for the external function calls. After doing so, the original failure is avoided.

7.3.2 Oblivion of CWE.

We notice that LLMs occasionally ‘forget’ the CWE they are analyzing, possibly due to the great length of input and output text (discussed in Section 4.3). To verify this, we conducted a code length analysis for different failure reasons on the CVE dataset, as presented in Table 8. The average length for samples exhibiting ‘oblivion’ of CWE cases is notably higher than for others. This suggests that ‘oblivion’ is more likely to occur in longer code samples.

Samples	Average #bytes
Insufficient context cases	4,222
Oblivion of CWE cases	5,881
Incomplete control flow analysis	4,254
Incomplete data flow analysis	3,154
All CVE samples	3,854

Table 8: Average #bytes in the failure cases versus all the samples from the CVE dataset.

A potential remedy for this issue is to relocate the question after the code sample and explicitly define the meaning of the CWEs. An example of vulnerability identification is provided in Figure 6 in the Appendix. After doing this, the generated text is closer to the CWE ID with explicit meaning in the question, which prevents the “forgetting” issue.

7.3.3 Incomplete Control and Data Flow Analysis

We notice that, while LLMs have the ability to understand code semantics and perform code-based analysis to some extent, they fall short of conducting comprehensive control and data flow analysis, comparable to conventional static/dynamic techniques. Given the complexity of real-world code, replete with various control flow (e.g., branching) structures and variable definitions/uses, relying solely on LLMs is insufficient as it could lead to exceedingly long reasoning processes.

Thus, for advanced vulnerability analysis, we recommend integrating traditional code analysis techniques with VSP-based approaches. Specifically, static code analysis tools may be employed to extract the contexts of (potentially) vulnerable lines, as the actual vulnerability contexts may be located far from these lines.

7.4 Comparison to Recent Works

Comparison to LLM-based Works. Pearce et al. [65] recently investigated zero-shot vulnerability repair using LLMs, conducting experiments on automatically generated, hand-crafted, and real-world datasets. They assessed various zero-shot prompting strategies and parameter configurations. However, their datasets were tailored specifically for vulnerability repair testing and are relatively straightforward. Additionally, their real-world dataset included the edited line directly in the prompt, which is less practical. In contrast, our study evaluates LLMs on publicly available datasets with realistic conditions, providing only the vulnerable line. Furthermore, our novel prompting strategy, focusing on vulnerability semantics with exemplars, offers a comprehensive evaluation of the potential and limitations of LLMs.

Comparison to Traditional DL-based Works. DL-based vulnerability analysis has shown promising effectiveness in both detection and repair [11, 20, 48, 53, 86]. However, their performance is often overestimated due to unrealistic testing setups, such as using part of training sets for testing [64]. When evaluated on independent (unseen) real-world testing

sets, these techniques yield much lower results, with detection techniques achieving up to 16.43% F1 and repair techniques up to 8.55% top-1 accuracy [61]. One way to mitigate the poor performance is data augmentation [62, 63]. However, even after augmenting the training dataset with 15,039 high-quality vulnerable samples and even more normal samples using the latest data-augmentation technique, those numbers only went up to 20.1% for detection and 21.05% for repair [61]. In contrast, VSP achieves up to 48.35% F1 for vulnerability discovery (more challenging than their binary detection), and up to 20% top-1 accuracy for patching using just 20 exemplars. While our real-world testing dataset is different from those in [61], VSP on LLMs shows better potential than existing DL-based approaches to vulnerability analysis.

8 Related Work

Vulnerability identification/discovery. Traditionally, vulnerability detection is addressed through static and/or dynamic code analysis [42, 60]. For instance, PCA [43] detects memory leaks via static data-flow analysis focusing on efficiency optimization, while KMeld [13] targets the same type of vulnerabilities induced by specialized memory allocation/deallocation functions. CBMC [38] discovers a range of memory-error related vulnerabilities through (static) model checking, validating assertions against memory-safety violations.

With dynamic analysis, undangle [10] identifies use-after-free and double-free vulnerabilities via searching dangling pointers, and TT-XSS [73] identifies DOM cross-site scripting (XSS) vulnerabilities via dynamic taint tracking. Both targeting buffer overruns, Lhee and Chapin [40] focuses on array boundary checking, while Cred [67] checks the bounds of various kinds of memory accesses. More broadly, IntentDroid [27] detects eight types of inter-app communication (IAC) vulnerabilities as a result of unsafe handling of incoming IAC messages, while DrMemory [9] and Valgrind [56] discover memory-safety vulnerabilities through memory shadowing. Similarly, AddressSanitizer [68] also discovers a variety of out-of-bounds access as well as use-after-free errors, while FlowDist [22] and PolyCruise [44] detects various types of taint-style vulnerabilities—but these techniques work by combining static and dynamic analysis techniques.

A main class of dynamic approach is fuzzing, which generates run-time inputs to trigger vulnerabilities [87]. For instance, UAFuzz [57] identifies use-after-free (UaF) vulnerabilities through directed greybox fuzzing, while UAFL [71] models the same type of vulnerabilities as tpestate properties and checks property violations during fuzzing. FUZE [79] also focuses on detecting UaF bugs in OS kernels by combining kernel fuzzing and symbolic execution. Likewise, Dowser [26] addresses a particular kind of (i.e., buffer overflow/underflow) vulnerabilities using taint tracking combined with symbolic execution. More fuzzing approaches, however, are devised to discover a wider range of vulnerabilities [25, 45, 52, 54].

Another major direction in vulnerability detection is to leverage machine learning, especially deep learning (DL) [11, 64]. For example, VulCNN [81] detects vulnerabilities by modeling programs as images hence leveraging the merits of convolutional neural network (CNN). Like Devign [86], VulChecker [53] learns a graph neural network (GNN) based program representation for detecting vulnerabilities. Many other DL-based approaches, such as LineVul [20] and LineVD [30], detect vulnerabilities through sequence modeling of code as natural language tokens based on Transformer [70]. In addition, IVDetect [46] offers explainability alongside detected vulnerabilities, and like LineVul and LineVD it advances over function-level detection [11, 47].

Our work explores vulnerability identification/discovery using LLMs, which generally falls in the DL-based category. A key difference lies in that traditional DL-based detection relies on a sizable labeled training dataset, which LLM-prompting-based like ours only needs a few prompting exemplars.

Vulnerability patching/repair. VuRLE [51] repairs vulnerable code by clustering code transformation edits in a set of repair examples, similar to Seader [85] using fixing edit patterns. ExtractFix [24] fixes a vulnerability for which the test (exploit) is available using symbolic execution. VRepair [12] attempts to fix security vulnerabilities by utilizing knowledge learned from functionality-bug fixes through transfer learning based on a vanilla Transformer [70]. Also by fine-tuning Transformer but leveraging a pre-trained code model, VulRepair [21] improves repair accuracy over VRepair by using the T5 Transformer [74] along with the BPE tokenization [23]. Lately, Pearce et al. [65] applied several LLMs in the zero-shot setting to vulnerability repair, showing the challenges with repairing real-world vulnerabilities.

In comparison, we explore LLM-prompting-based approaches which do not rely on (sizable) fine-tuning datasets or known exploits. Also, unlike [65], we also examine various settings beyond zero-shot on LLMs.

Prompting LLMs. Different from prompt learning [29, 50] and fine tuning [83] as part of model *training* (which thus requires downstream-task-specific labeled datasets), prompting is an *inference*-time technique to improve (pre-trained) model’s responses. It also does not iteratively adjust prompts as in prompt tuning [39]. For instance, chain of thought (CoT) prompting elicits complex multi-step reasoning through step-by-step answer examples [75], while zero-shot CoT is a CoT variant replacing those examples with a simple prompt (“Let’s think step by step”) [37]. Later, tree of thoughts (ToT) generalizes over CoT by considering multiple different reasoning paths to allow for deliberate decision making [84], and graph of thoughts (GoT) [6] further generalizes CoT by modeling the LLM’s reasoning process as a graph, enhancing model capabilities through networked reasoning.

In contrast, while our VSP approach is initially inspired by the general CoT methodology, it differs from it in focusing on selectively prompting LLMs only with the thoughts (i.e., vul-

nerability semantics) that are most relevant to the downstream tasks (i.e., vulnerability analysis).

9 Conclusion

We performed the first extensive study exploring how to leverage the potential of LLMs for software vulnerability analysis through vulnerability-semantics-guided prompting (VSP). Inspired by and instantiating chain-of-thought (CoT) prompting, VSP focuses on the most essential program behaviors that cause vulnerabilities when demonstrating to LLMs with the vulnerability analysis reasoning steps. Our experiments and case studies on three representative defense tasks against software vulnerabilities (identification, discovery, and patching) on two datasets and three LLMs reveal impressive merits of VSP over five LLM-based approaches as baselines.

References

- [1] 2022 cwe top 25 most dangerous software weaknesses. https://cwe.mitre.org/top25/archive/2022/2022_cwe_top25.html, 2022.
- [2] Alfred V Aho, Monica S Lam, Ravi Sethi, and Jeffrey D Ullman. Compilers: Principles, techniques, and tools, 2006.
- [3] Nuno Antunes and Marco Vieira. Comparing the effectiveness of penetration testing and static code analysis on the detection of SQL injection vulnerabilities in web services. In *Pacific Rim International Symposium on Dependable Computing*, pages 301–306, 2009.
- [4] Masaki Aota, Hideaki Kanehara, Masaki Kubo, Noboru Murata, Bo Sun, and Takeshi Takahashi. Automation of vulnerability classification from its description using machine learning. In *2020 IEEE Symposium on Computers and Communications (ISCC)*, pages 1–7. IEEE, 2020.
- [5] Andrew Austin, Casper Holmgreen, and Laurie Williams. A comparison of the efficiency and effectiveness of vulnerability discovery techniques. *Information and Software Technology*, 55(7):1279–1288, 2013.
- [6] Maciej Besta, Nils Blach, Ales Kubicek, Robert Gerstenberger, Lukas Gianinazzi, Joanna Gajda, Tomasz Lehmann, Michal Podstawski, Hubert Niewiadomski, Piotr Nyczyk, et al. Graph of thoughts: Solving elaborate problems with large language models. *arXiv preprint arXiv:2308.09687*, 2023.
- [7] Paul E Black et al. SARD: A software assurance reference dataset. In *Anonymous Cybersecurity Innovation Forum*(.), 2017.
- [8] Tom Brown, Benjamin Mann, Nick Ryder, Melanie Subbiah, Jared D Kaplan, Prafulla Dhariwal, Arvind Neelakantan, Pranav Shyam, Girish Sastry, Amanda Askell, et al. Language models are few-shot learners. *Advances in neural information processing systems*, 33:1877–1901, 2020.
- [9] Derek Bruening and Qin Zhao. Practical memory checking with dr. memory. In *International Symposium on Code Generation and Optimization (CGO 2011)*, pages 213–223. IEEE, 2011.
- [10] Juan Caballero, Gustavo Grieco, Mark Marron, and Antonio Nappa. Undangle: early detection of dangling pointers in use-after-free and double-free vulnerabilities. In *Proceedings of the 2012 International Symposium on Software Testing and Analysis*, pages 133–143, 2012.
- [11] Saikat Chakraborty, Rahul Krishna, Yangruibo Ding, and Baishakhi Ray. Deep learning based vulnerability detection: Are we there yet. *IEEE Transactions on Software Engineering (TSE)*, 2021.
- [12] Zimin Chen, Steve Kommrusch, and Martin Monperrus. Neural transfer learning for repairing security vulnerabilities in c code. *IEEE Transactions on Software Engineering*, 49(1):147–165, 2022.
- [13] Navid Emamdoost, Qiushi Wu, Kangjie Lu, and Stephen McCamant. Detecting kernel memory leaks in specialized modules with ownership reasoning. In *The 2021 Annual Network and Distributed System Security Symposium (NDSS’21)*, 2021.
- [14] Ericsson. Software vulnerability: Impact & ways to avoid it. <https://www.ericsson.com/en/security/vulnerability-management>, 2023.
- [15] Angela Fan, Beliz Gokkaya, Mark Harman, Mitya Lyubarskiy, Shubho Sengupta, Shin Yoo, and Jie M Zhang. Large language models for software engineering: Survey and open problems. *arXiv preprint arXiv:2310.03533*, 2023.
- [16] Jiahao Fan, Yi Li, Shaohua Wang, and Tien N Nguyen. A c/c++ code vulnerability dataset with code changes and cve summaries. In *Proceedings of the 17th International Conference on Mining Software Repositories (MSR)*, pages 508–512, 2020.
- [17] Sidong Feng and Chunyang Chen. Prompting is all your need: Automated android bug replay with large language models. *arXiv preprint arXiv:2306.01987*, 2023.
- [18] Luciano Floridi and Massimo Chiriatti. Gpt-3: Its nature, scope, limits, and consequences. *Minds and Machines*, 30:681–694, 2020.

- [19] Forbes Technology Council. Zero-day vulnerabilities: 17 consequences and complications. <https://www.forbes.com/sites/forbestechcouncil/2023/05/26/zero-day-vulnerabilities-17-consequences-and-complications/?sh=711e37204b41>, 2023.
- [20] Michael Fu and Chakkrit Tantithamthavorn. LineVul: a transformer-based line-level vulnerability prediction. In *Proceedings of the 19th International Conference on Mining Software Repositories (MSR)*, pages 608–620, 2022.
- [21] Michael Fu, Chakkrit Tantithamthavorn, Trung Le, Van Nguyen, and Dinh Phung. VulRepair: a t5-based automated software vulnerability repair. In *Proceedings of the 30th ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering (ESEC/FSE)*, pages 935–947, 2022.
- [22] Xiaoqin Fu and Haipeng Cai. FlowDist:multi-staged refinement-based dynamic information flow analysis for distributed software systems. In *30th USENIX Security Symposium (USENIX Security 21)*, pages 2093–2110, 2021.
- [23] Philip Gage. A new algorithm for data compression. *C Users Journal*, 12(2):23–38, 1994.
- [24] Xiang Gao, Bo Wang, Gregory J Duck, Ruyi Ji, Yingfei Xiong, and Abhik Roychoudhury. Beyond tests: Program vulnerability repair via crash constraint extraction. *ACM Transactions on Software Engineering and Methodology (TOSEM)*, 30(2):1–27, 2021.
- [25] google. A Coverage-Guided, Native Python Fuzzer. <https://github.com/google/atheris>, 2022.
- [26] Istvan Haller, Asia Slowinska, Matthias Neugschwandtner, and Herbert Bos. Dowsing for Overflows: A guided fuzzer to find buffer boundary violations. In *22nd USENIX Security Symposium (USENIX Security 13)*, pages 49–64, Washington, D.C., August 2013. USENIX Association.
- [27] Roei Hay, Omer Tripp, and Marco Pistoia. Dynamic detection of inter-application communication vulnerabilities in android. In *Proceedings of the 2015 International Symposium on Software Testing and Analysis*, pages 118–128, 2015.
- [28] Jingxuan He and Martin Vechev. Controlling large language models to generate secure and vulnerable code. *arXiv preprint arXiv:2302.05319*, 2023.
- [29] Xinlei He, Savvas Zannettou, Yun Shen, and Yang Zhang. You only prompt once: On the capabilities of prompt learning on large language models to tackle toxic content. *arXiv preprint arXiv:2308.05596*, 2023.
- [30] David Hin, Andrey Kan, Huaming Chen, and M Ali Babar. LineVD: statement-level vulnerability detection using graph neural networks. In *Proceedings of the 19th International Conference on Mining Software Repositories (MSR)*, pages 596–607, 2022.
- [31] Emanuele Iannone, Roberta Guadagni, Filomena Ferrucci, Andrea De Lucia, and Fabio Palomba. The secret life of software vulnerabilities: A large-scale empirical study. *IEEE Transactions on Software Engineering*, 49(1):44–63, 2022.
- [32] Ilan Peleg. The high cost of security vulnerabilities. <https://www.forbes.com/sites/forbesbusinesscouncil/2023/04/10/the-high-cost-of-security-vulnerabilities-why-observability-is-the-solution/?sh=90da08612ae6>, 2023.
- [33] Information Technology Laboratory at NIST. National vulnerability database (nvd) dashboard. <https://nvd.nist.gov/general/nvd-dashboard>, 2023.
- [34] Brittany Johnson, Yoonki Song, Emerson Murphy-Hill, and Robert Bowdidge. Why don’t software developers use static analysis tools to find bugs? In *2013 35th International Conference on Software Engineering (ICSE)*, pages 672–681. IEEE, 2013.
- [35] Harshit Joshi, José Cambronero Sanchez, Sumit Gulwani, Vu Le, Gust Verbruggen, and Ivan Radiček. Repair is nearly generation: Multilingual program repair with llms. In *Proceedings of the AAAI Conference on Artificial Intelligence*, volume 37, pages 5131–5140, 2023.
- [36] Sungmin Kang, Juyeon Yoon, and Shin Yoo. Large language models are few-shot testers: Exploring llm-based general bug reproduction. In *2023 IEEE/ACM 45th International Conference on Software Engineering (ICSE)*, pages 2312–2323. IEEE, 2023.
- [37] Takeshi Kojima, Shixiang Shane Gu, Machel Reid, Yutaka Matsuo, and Yusuke Iwasawa. Large language models are zero-shot reasoners. *Advances in neural information processing systems*, 35:22199–22213, 2022.
- [38] Daniel Kroening and Michael Tautschnig. CBMC–c bounded model checker. In *International Conference on Tools and Algorithms for the Construction and Analysis of Systems (TACAS)*, pages 389–391, 2014.
- [39] Brian Lester, Rami Al-Rfou, and Noah Constant. The power of scale for parameter-efficient prompt tuning. *arXiv preprint arXiv:2104.08691*, 2021.
- [40] Kyung-suk Lhee and Steve J Chapin. {Type-Assisted} dynamic buffer overflow detection. In *11th USENIX Security Symposium (USENIX Security 02)*, 2002.

- [41] Haonan Li, Yu Hao, Yizhuo Zhai, and Zhiyun Qian. The hitchhiker’s guide to program analysis: A journey with large language models. *arXiv preprint arXiv:2308.00245*, 2023.
- [42] Peng Li and Baojiang Cui. A comparative study on software vulnerability static analysis techniques and tools. In *International Conference on Information Theory and Information Security*, pages 521–524, 2010.
- [43] Wen Li, Haipeng Cai, Yulei Sui, and David Manz. PCA: memory leak detection using partial call-path analysis. In *Proceedings of the 28th ACM Joint Meeting on European Software Engineering Conference and Symposium on the Foundations of Software Engineering (ESEC/FSE-Demo)*, pages 1621–1625, 2020.
- [44] Wen Li, Jiang Ming, Xiapu Luo, and Haipeng Cai. {PolyCruise}: A {Cross-Language} dynamic information flow analysis. In *31st USENIX Security Symposium (USENIX Security 22)*, pages 2513–2530, 2022.
- [45] Wen Li, Jinyang Ruan, Guangbei Yi, Long Cheng, Xiapu Luo, and Haipeng Cai. PolyFuzz: Holistic greybox fuzzing of multi-language systems. In *32nd USENIX Security Symposium (USENIX Security 23)*, 2023.
- [46] Yi Li, Shaohua Wang, and Tien N Nguyen. Vulnerability detection with fine-grained interpretations. In *Proceedings of the 29th ACM Joint Meeting on European Software Engineering Conference and Symposium on the Foundations of Software Engineering*, pages 292–303, 2021.
- [47] Zhen Li, Deqing Zou, Shouhuai Xu, Hai Jin, Yawei Zhu, and Zhaoxuan Chen. Sysevr: A framework for using deep learning to detect software vulnerabilities. *IEEE Transactions on Dependable and Secure Computing*, 2021.
- [48] Zhen Li, Deqing Zou, Shouhuai Xu, Xinyu Ou, Hai Jin, Sujuan Wang, Zhijun Deng, and Yuyi Zhong. Vuldeep-ecker: A deep learning-based system for vulnerability detection. In *Network and Distributed System Security (NDSS) Symposium*, 2018.
- [49] Jiawei Liu, Chunqiu Steven Xia, Yuyao Wang, and Lingming Zhang. Is your code generated by chatgpt really correct? rigorous evaluation of large language models for code generation. *arXiv preprint arXiv:2305.01210*, 2023.
- [50] Pengfei Liu, Weizhe Yuan, Jinlan Fu, Zhengbao Jiang, Hiroaki Hayashi, and Graham Neubig. Pre-train, prompt, and predict: A systematic survey of prompting methods in natural language processing. *ACM Computing Surveys*, 55(9):1–35, 2023.
- [51] Siqi Ma, Ferdian Thung, David Lo, Cong Sun, and Robert H Deng. Vurle: Automatic vulnerability detection and repair by learning from examples. In *Computer Security–ESORICS 2017: 22nd European Symposium on Research in Computer Security, Oslo, Norway, September 11–15, 2017, Proceedings, Part II 22*, pages 229–246. Springer, 2017.
- [52] Valentin JM Manès, HyungSeok Han, Choongwoo Han, Sang Kil Cha, Manuel Egele, Edward J Schwartz, and Maverick Woo. The art, science, and engineering of fuzzing: A survey. *IEEE Transactions on Software Engineering*, 47(11):2312–2331, 2019.
- [53] Yisroel Mirsky, George Macon, Michael Brown, Carter Yagemann, Matthew Pruett, Evan Downing, Sukarno Mertoguno, and Wenke Lee. VulChecker: Graph-based vulnerability localization in source code. In *32nd USENIX Security Symposium (USENIX Security 23)*, pages 6557–6574, Anaheim, CA, August 2023. USENIX Association.
- [54] M.Zalewski. Technical "whitepaper" for afl-fuzz. https://lcamtuf.coredump.cx/afl/technical_details.txt, 2014.
- [55] National Institute of Standards and Technology (NIST). National Vulnerability Database (NVD). <https://nvd.nist.gov>, 2022.
- [56] Nicholas Nethercote and Julian Seward. Valgrind: a framework for heavyweight dynamic binary instrumentation. *ACM Sigplan notices*, 42(6):89–100, 2007.
- [57] Manh-Dung Nguyen, Sébastien Bardin, Richard Bonichon, Roland Groz, and Matthieu Lemerre. Binary-level directed fuzzing for {Use-After-Free} vulnerabilities. In *23rd International Symposium on Research in Attacks, Intrusions and Defenses (RAID 2020)*, pages 47–62, 2020.
- [58] David Noever. Can large language models find and fix vulnerable software? *arXiv preprint arXiv:2308.10345*, 2023.
- [59] Yu Nong and Haipeng Cai. A preliminary study on open-source memory vulnerability detectors. In *2020 IEEE 27th International Conference on Software Analysis, Evolution and Reengineering (SANER)*, pages 557–561. IEEE, 2020.
- [60] Yu Nong, Haipeng Cai, Pengfei Ye, Li Li, and Feng Chen. Evaluating and comparing memory error vulnerability detectors. *Information and Software Technology*, 137:106614, 2021.

- [61] Yu Nong, Richard Fang, Guangbei Yi, Kunsong Zhao, Xiapu Luo, Feng Chen, and Haipeng Cai. VGX: Large-scale sample generation for boosting learning-based software vulnerability analyses. In *IEEE/ACM International Conference on Software Engineering (ICSE)*, 2024.
- [62] Yu Nong, Yuzhe Ou, Michael Pradel, Feng Chen, and Haipeng Cai. Generating realistic vulnerabilities via neural code editing: an empirical study. In *Proceedings of the 30th ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering*, pages 1097–1109, 2022.
- [63] Yu Nong, Yuzhe Ou, Michael Pradel, Feng Chen, and Haipeng Cai. VulGen: Realistic vulnerable sample generation via pattern mining and deep learning. In *IEEE/ACM International Conference on Software Engineering (ICSE)*, pages 2527–2539, 2023.
- [64] Yu Nong, Rainy Sharma, Abdelwahab Hamou-Lhadj, Xiapu Luo, and Haipeng Cai. Open science in software engineering: A study on deep learning-based vulnerability detection. *IEEE Transactions on Software Engineering (TSE)*, 2022.
- [65] Hammond Pearce, Benjamin Tan, Baleegh Ahmad, Ramesh Karri, and Brendan Dolan-Gavitt. Examining zero-shot vulnerability repair with large language models. In *2023 IEEE Symposium on Security and Privacy (SP)*, pages 2339–2356. IEEE, 2023.
- [66] Andre Protas and Steve Manzuik. Skeletons in microsoft’s closet - silently fixed vulnerabilities. <https://www.blackhat.com/presentations/bh-europe-06/bh-eu-06-Manzuik.pdf>, 2023.
- [67] Olatunji Ruwase and Monica S Lam. A practical dynamic buffer overflow detector. In *NDSS*, volume 2004, pages 159–169, 2004.
- [68] Konstantin Serebryany, Derek Bruening, Alexander Potapenko, and Dmitriy Vyukov. {AddressSanitizer}: A fast address sanity checker. In *2012 USENIX annual technical conference (USENIX ATC 12)*, pages 309–318, 2012.
- [69] Hugo Touvron, Louis Martin, Kevin Stone, Peter Albert, Amjad Almahairi, Yasmine Babaei, Nikolay Bashlykov, Soumya Batra, Prajjwal Bhargava, Shruti Bhosale, et al. Llama 2: Open foundation and fine-tuned chat models. *arXiv preprint arXiv:2307.09288*, 2023.
- [70] Ashish Vaswani, Noam Shazeer, Niki Parmar, Jakob Uszkoreit, Llion Jones, Aidan N Gomez, Łukasz Kaiser, and Illia Polosukhin. Attention is all you need. *Advances in Neural Information Processing Systems (NeurIPS)*, 30, 2017.
- [71] Haijun Wang, Xiaofei Xie, Yi Li, Cheng Wen, Yuekang Li, Yang Liu, Shengchao Qin, Hongxu Chen, and Yulei Sui. Tpestate-guided fuzzer for discovering use-after-free vulnerabilities. In *Proceedings of the ACM/IEEE 42nd International Conference on Software Engineering*, pages 999–1010, 2020.
- [72] Junjie Wang, Yuchao Huang, Chunyang Chen, Zhe Liu, Song Wang, and Qing Wang. Software testing with large language model: Survey, landscape, and vision. *arXiv preprint arXiv:2307.07221*, 2023.
- [73] Ran Wang, Guangquan Xu, Xianjiao Zeng, Xiaohong Li, and Zhiyong Feng. Tt-xss: A novel taint tracking based dynamic detection framework for dom cross-site scripting. *Journal of Parallel and Distributed Computing*, 118:100–106, 2018.
- [74] Yue Wang, Weishi Wang, Shafiq Joty, and Steven CH Hoi. CodeT5: Identifier-aware unified pre-trained encoder-decoder models for code understanding and generation. *arXiv preprint arXiv:2109.00859*, 2021.
- [75] Jason Wei, Xuezhi Wang, Dale Schuurmans, Maarten Bosma, Fei Xia, Ed Chi, Quoc V Le, Denny Zhou, et al. Chain-of-thought prompting elicits reasoning in large language models. *Advances in Neural Information Processing Systems*, 35:24824–24837, 2022.
- [76] Yuxiang Wei, Chunqiu Steven Xia, and Lingming Zhang. Copiloting the copilots: Fusing large language models with completion engines for automated program repair. *arXiv preprint arXiv:2309.00608*, 2023.
- [77] Jules White, Quchen Fu, Sam Hays, Michael Sandborn, Carlos Olea, Henry Gilbert, Ashraf Elnashar, Jesse Spencer-Smith, and Douglas C Schmidt. A prompt pattern catalog to enhance prompt engineering with chatgpt. *arXiv preprint arXiv:2302.11382*, 2023.
- [78] Thomas Wolf, Lysandre Debut, Victor Sanh, Julien Chaumond, Clement Delangue, Anthony Moi, Pierric Cistac, Tim Rault, Rémi Louf, Morgan Funtowicz, et al. Huggingface’s transformers: State-of-the-art natural language processing. *arXiv preprint arXiv:1910.03771*, 2019.
- [79] Wei Wu, Yueqi Chen, Jun Xu, Xinyu Xing, Xiaorui Gong, and Wei Zou. {FUZE}: Towards facilitating exploit generation for kernel {Use-After-Free} vulnerabilities. In *27th USENIX Security Symposium (USENIX Security 18)*, pages 781–797, 2018.
- [80] Yi Wu, Nan Jiang, Hung Viet Pham, Thibaud Lutellier, Jordan Davis, Lin Tan, Petr Babkin, and Sameena Shah. How effective are neural networks for fixing security vulnerabilities. *arXiv preprint arXiv:2305.18607*, 2023.

- [81] Yueming Wu, Deqing Zou, Shihan Dou, Wei Yang, Duo Xu, and Hai Jin. Vulcnn: An image-inspired scalable vulnerability detection system. In *Proceedings of the 44th International Conference on Software Engineering*, pages 2365–2376, 2022.
- [82] Chunqiu Steven Xia, Matteo Paltenghi, Jia Le Tian, Michael Pradel, and Lingming Zhang. Universal fuzzing via large language models. *arXiv preprint arXiv:2308.04748*, 2023.
- [83] Guanqun Yang, Shay Dineen, Zhipeng Lin, and Xueqing Liu. Few-sample named entity recognition for security vulnerability reports by fine-tuning pre-trained language models. In *Deployable Machine Learning for Security Defense: Second International Workshop, MLHat 2021, Virtual Event, August 15, 2021, Proceedings 2*, pages 55–78. Springer, 2021.
- [84] Shunyu Yao, Dian Yu, Jeffrey Zhao, Izhak Shafran, Thomas L Griffiths, Yuan Cao, and Karthik Narasimhan. Tree of thoughts: Deliberate problem solving with large language models. *arXiv preprint arXiv:2305.10601*, 2023.
- [85] Ying Zhang, Ya Xiao, Md Mahir Asef Kabir, Danfeng Yao, and Na Meng. Example-based vulnerability detection and repair in java code. In *Proceedings of the 30th IEEE/ACM International Conference on Program Comprehension*, pages 190–201, 2022.
- [86] Yaqin Zhou, Shangqing Liu, Jingkai Siow, Xiaoning Du, and Yang Liu. Devign: Effective vulnerability identification by learning comprehensive program semantics via graph neural networks. *Advances in Neural Information Processing Systems (NeurIPS)*, 32, 2019.
- [87] Xiaogang Zhu, Sheng Wen, Seyit Camtepe, and Yang Xiang. Fuzzing: a survey for roadmap. *ACM Computing Surveys (CSUR)*, 54(11s):1–36, 2022.
- [88] Yoshua X ZXhang, Yann M Haxo, and Ying X Mat. Falcon llm: A new frontier in natural language processing. *AC Investment Research Journal*, 220(44), 2023.

Appendices

A Full Results for each Task

Task 1. Tables 9, 10, and 11 show the recall, precision, and F1 of each CWE for Task 1.

Task 2. Tables 12, 13, and 14 show the recall, precision, and F1 of each CWE for Task 2.

Task 3. Table 15 show the accuracy of each CWE for Task 3.

B Zero-day vulnerability discovery

The full list of the latest CVEs that VSP prompting and standard prompting can and cannot discover is shown in Table 16.

C Failure Reasons and Recommendations

Figures 5 and 6 show the examples for the failure reasons "insufficient contexts" and "oblivion of CWE" as well as their possible solutions.

Model	Dataset	Strategy	CWE-787	CWE-125	CWE-416	CWE-476	CWE-190	Macro avg	Micro avg
GPT-3.5	SARD	Standard Prompting	68.56%	71.54%	10.00%	75.00%	0.77%	45.17%	50.60%
		Standard Few-Shot	32.31%	34.96%	20.00%	37.50%	3.08%	25.57%	25.20%
		Naive CoT Learning	12.23%	8.94%	30.00%	12.50%	0.00%	12.73%	8.62%
		Zero-Shot VSP	83.84%	82.11%	40.00%	37.50%	3.85%	49.46%	60.92%
		VSP Prompting	61.57%	66.67%	60.00%	100.00%	84.62%	74.57%	69.40%
		Other-Type VSP	78.17%	82.11%	90.00%	87.50%	84.62%	84.48%	81.36%
	CVE	Standard Prompting	2.60%	1.96%	0.00%	0.00%	0.00%	0.91%	1.86%
		Standard Few-Shot	0.73%	0.00%	0.00%	0.00%	0.00%	0.15%	0.40%
		Naive CoT Learning	5.09%	7.84%	2.13%	2.78%	0.00%	3.57%	4.81%
		Zero-Shot VSP	3.27%	1.94%	0.00%	0.00%	2.56%	1.56%	2.41%
		VSP Prompting	64.00%	79.41%	48.94%	75.00%	92.31%	71.93%	68.74%
		Other-Type VSP	65.45%	73.53%	48.94%	72.22%	69.23%	65.87%	66.33%
Llama2	SARD	Standard Prompting	58.52%	78.86%	40.00%	100.00%	99.23%	75.32%	74.40%
		Standard Few-Shot	56.77%	81.30%	70.00%	37.50%	59.23%	60.96%	63.40%
		Naive CoT Learning	48.91%	58.54%	30.00%	25.00%	33.08%	39.10%	46.40%
		Zero-Shot VSP	63.76%	68.29%	20.00%	37.50%	43.08%	46.53%	58.20%
		VSP Prompting	72.05%	76.42%	80.00%	37.50%	77.69%	68.73%	74.20%
		Other-Type VSP	71.95%	68.54%	50.00%	85.71%	81.72%	71.59%	73.54%
	CVE	Standard Prompting	24.44%	27.45%	27.66%	25.00%	35.90%	28.09%	26.43%
		Standard Few-Shot	25.28%	20.59%	29.79%	19.44%	33.33%	25.69%	25.00%
		Naive CoT Learning	19.78%	5.88%	6.38%	8.33%	17.95%	11.66%	14.64%
		Zero-Shot VSP	29.85%	39.22%	29.79%	44.44%	30.77%	34.81%	32.58%
		VSP Prompting	36.94%	35.29%	57.45%	41.67%	61.54%	46.58%	40.74%
		Other-Type VSP	41.42%	32.35%	46.81%	38.89%	51.28%	42.15%	40.62%
Falcon	SARD	Standard Prompting	0.00%	0.00%	0.00%	0.00%	0.00%	0.00%	0.00%
		Standard Few-Shot	54.15%	48.78%	40.00%	25.00%	50.00%	43.59%	51.00%
		Naive CoT Learning	2.76%	19.19%	12.50%	0.00%	30.36%	12.96%	14.53%
		Zero-Shot VSP	0.44%	0.00%	10.00%	0.00%	0.77%	2.24%	0.60%
		VSP Prompting	48.91%	55.28%	50.00%	25.00%	53.85%	46.61%	51.40%
		Other-Type VSP	53.71%	42.28%	40.00%	37.50%	50.00%	44.70%	49.40%
	CVE	Standard Prompting	2.24%	1.96%	2.13%	8.33%	0.00%	2.93%	2.46%
		Standard Few-Shot	22.71%	13.73%	34.04%	27.78%	28.21%	25.29%	22.42%
		Naive CoT Learning	15.99%	15.69%	8.51%	11.11%	23.08%	14.87%	15.34%
		Zero-Shot VSP	16.79%	17.65%	14.89%	8.33%	12.82%	14.10%	15.78%
		VSP Prompting	25.56%	29.41%	38.30%	25.00%	38.46%	31.35%	28.46%
		Other-Type VSP	24.91%	28.43%	40.43%	27.78%	20.51%	28.41%	26.79%

Table 9: Full vulnerability identification effectiveness in terms of recall.

Model	Dataset	Strategy	CWE-787	CWE-125	CWE-416	CWE-476	CWE-190	Macro avg	Micro avg
GPT-3.5	SARD	Standard Prompting	60.15%	68.22%	100.00%	100.00%	50.00%	75.67%	63.41%
		Standard Few-Shot	50.68%	51.81%	66.67%	100.00%	66.67%	67.17%	52.28%
		Naive CoT Learning	57.14%	73.33%	100.00%	100.00%	0.00%	66.10%	63.24%
		Zero-Shot VSP	53.48%	50.00%	100.00%	100.00%	20.83%	64.86%	51.44%
		VSP Prompting	66.20%	67.21%	50.00%	72.73%	53.66%	61.96%	61.63%
		Other-Type VSP	54.57%	55.80%	56.25%	77.78%	50.69%	59.02%	54.21%
	CVE	Standard Prompting	53.85%	50.00%	0.00%	0.00%	0.00%	20.77%	52.94%
		Standard Few-Shot	66.67%	0.00%	0.00%	0.00%	0.00%	13.33%	66.67%
		Naive CoT Learning	63.64%	72.73%	50.00%	100.00%	0.00%	57.27%	64.86%
		Zero-Shot VSP	60.00%	50.00%	0.00%	0.00%	33.33%	28.67%	54.55%
		VSP Prompting	51.16%	52.26%	42.59%	50.94%	50.70%	49.53%	50.89%
		Other-Type VSP	49.45%	48.70%	46.94%	52.00%	45.76%	48.57%	48.96%
Llama2	SARD	Standard Prompting	38.29%	44.91%	30.77%	50.00%	49.81%	42.75%	43.56%
		Standard Few-Shot	55.56%	49.02%	50.00%	75.00%	47.53%	55.42%	51.29%
		Naive CoT Learning	49.12%	49.66%	37.50%	40.00%	48.86%	45.03%	48.95%
		Zero-Shot VSP	50.34%	48.55%	25.00%	33.33%	49.56%	41.36%	49.07%
		VSP Prompting	51.89%	48.45%	57.14%	100.00%	49.51%	61.40%	50.61%
		Other-Type VSP	50.21%	48.41%	33.33%	54.55%	50.67%	47.43%	49.72%
	CVE	Standard Prompting	53.23%	52.83%	50.00%	45.00%	53.85%	50.98%	52.23%
		Standard Few-Shot	53.13%	51.22%	53.85%	70.00%	50.00%	55.64%	53.51%
		Naive CoT Learning	51.46%	35.29%	50.00%	60.00%	63.64%	52.08%	50.71%
		Zero-Shot VSP	53.33%	53.33%	48.28%	48.48%	48.00%	50.29%	52.32%
		VSP Prompting	49.75%	46.15%	50.94%	53.57%	52.17%	50.52%	49.75%
		Other-Type VSP	47.03%	53.23%	46.81%	48.28%	45.45%	48.16%	48.05%
Falcon	SARD	Standard Prompting	0.00%	0.00%	0.00%	0.00%	0.00%	0.00%	0.00%
		Standard Few-Shot	51.03%	48.00%	36.36%	40.00%	48.87%	44.85%	49.32%
		Naive CoT Learning	31.25%	63.33%	25.00%	0.00%	55.74%	35.06%	51.75%
		Zero-Shot VSP	100.00%	0.00%	100.00%	0.00%	100.00%	60.00%	60.00%
		VSP Prompting	51.38%	55.74%	71.43%	25.00%	47.30%	50.17%	51.09%
		Other-Type VSP	54.19%	50.49%	40.00%	42.86%	49.24%	47.35%	51.57%
	CVE	Standard Prompting	54.55%	40.00%	33.33%	60.00%	0.00%	37.58%	50.00%
		Standard Few-Shot	48.82%	42.42%	50.00%	47.62%	44.00%	46.57%	47.44%
		Naive CoT Learning	48.86%	53.33%	44.44%	44.44%	50.00%	48.22%	49.34%
		Zero-Shot VSP	47.87%	56.25%	43.75%	60.00%	41.67%	49.91%	49.36%
		VSP Prompting	48.59%	53.57%	47.37%	56.25%	50.00%	51.16%	50.36%
		Other-Type VSP	49.63%	60.42%	59.38%	55.56%	36.36%	52.27%	52.19%

Table 10: Full vulnerability identification effectiveness in terms of precision.

Model	Dataset	Strategy	CWE-787	CWE-125	CWE-416	CWE-476	CWE-190	Macro avg	Micro avg
GPT-3.5	SARD	Standard Prompting	64.08%	69.84%	18.18%	85.71%	1.52%	47.87%	56.28%
		Standard Few-Shot	39.47%	41.75%	30.77%	54.55%	5.88%	34.48%	34.01%
		Naive CoT Learning	20.14%	15.94%	46.15%	22.22%	0.00%	20.89%	15.17%
		Zero-Shot VSP	65.31%	62.15%	57.14%	54.55%	6.49%	49.13%	55.78%
		VSP Prompting	63.80%	66.94%	54.55%	84.21%	65.67%	67.03%	65.29%
		Other-Type VSP	64.27%	66.45%	69.23%	82.35%	63.40%	69.14%	65.06%
	CVE	Standard Prompting	4.96%	3.77%	0.00%	0.00%	0.00%	1.75%	3.59%
		Standard Few-Shot	1.44%	0.00%	0.00%	0.00%	0.00%	0.29%	0.80%
		Naive CoT Learning	9.43%	14.16%	4.08%	5.41%	0.00%	6.61%	8.96%
		Zero-Shot VSP	6.21%	3.74%	0.00%	0.00%	4.76%	2.94%	4.62%
		VSP Prompting	56.87%	63.04%	45.54%	60.67%	65.45%	58.31%	58.48%
		Other-Type VSP	56.34%	58.59%	47.92%	60.47%	55.10%	55.68%	56.34%
Llama2	SARD	Standard Prompting	46.29%	57.23%	34.78%	66.67%	66.32%	54.26%	54.95%
		Standard Few-Shot	56.16%	61.16%	58.33%	50.00%	52.74%	55.68%	56.71%
		Naive CoT Learning	49.02%	53.73%	33.33%	30.77%	39.45%	41.26%	47.64%
		Zero-Shot VSP	56.26%	56.76%	22.22%	35.29%	46.09%	43.33%	53.25%
		VSP Prompting	60.33%	59.31%	66.67%	54.55%	60.48%	60.27%	60.18%
		Other-Type VSP	59.15%	56.74%	40.00%	66.67%	62.55%	57.02%	59.33%
	CVE	Standard Prompting	33.50%	36.13%	35.62%	32.14%	43.08%	36.09%	35.10%
		Standard Few-Shot	34.26%	29.37%	38.36%	30.43%	40.00%	34.48%	34.08%
		Naive CoT Learning	28.57%	10.08%	11.32%	14.63%	28.00%	18.52%	22.72%
		Zero-Shot VSP	38.28%	45.20%	36.84%	46.38%	37.50%	40.84%	40.15%
		VSP Prompting	42.40%	40.00%	54.00%	46.88%	56.47%	47.95%	44.80%
		Other-Type VSP	44.05%	40.24%	46.81%	43.08%	48.19%	44.47%	44.02%
Falcon	SARD	Standard Prompting	0.00%	0.00%	0.00%	0.00%	0.00%	0.00%	0.00%
		Standard Few-Shot	52.54%	48.39%	38.10%	30.77%	49.43%	43.84%	50.15%
		Naive CoT Learning	5.08%	29.46%	16.67%	0.00%	39.31%	18.10%	22.69%
		Zero-Shot VSP	0.87%	0.00%	18.18%	0.00%	1.53%	4.12%	1.19%
		VSP Prompting	50.11%	55.51%	58.82%	25.00%	50.36%	47.96%	51.25%
		Other-Type VSP	53.95%	46.02%	40.00%	40.00%	49.62%	45.92%	50.46%
	CVE	Standard Prompting	4.30%	3.74%	4.00%	14.63%	0.00%	5.33%	4.69%
		Standard Few-Shot	31.00%	20.74%	40.51%	35.09%	34.38%	32.34%	30.45%
		Naive CoT Learning	24.09%	24.24%	14.29%	17.78%	31.58%	22.39%	23.40%
		Zero-Shot VSP	24.86%	26.87%	22.22%	14.63%	19.61%	21.64%	23.91%
		VSP Prompting	33.50%	37.97%	42.35%	34.62%	43.48%	38.38%	36.36%
		Other-Type VSP	33.17%	38.67%	48.10%	37.04%	26.23%	36.64%	35.41%

Table 11: Full vulnerability identification effectiveness in terms of F1.

Model	Dataset	Strategy	CWE-787	CWE-125	CWE-476	CWE-416	CWE-190	Macro avg	Micro avg
GPT-3.5	SARD	Standard Prompt	83.84%	27.64%	75.00%	60.00%	76.92%	50.84%	49.60%
		Standard Few-shot	63.59%	35.77%	87.50%	90.00%	18.46%	59.06%	45.89%
		Naïve CoT Learning	42.79%	15.45%	75.00%	30.00%	2.31%	33.11%	25.80%
		Zero-Shot VSP	80.80%	21.21%	72.73%	45.45%	2.94%	44.63%	45.74%
		VSP Prompting	65.94%	52.03%	75.00%	30.00%	71.54%	58.90%	63.40%
		Other-Type VSP	77.29%	81.30%	62.50%	30.00%	73.08%	64.83%	76.00%
	CVE	Standard Prompt	5.09%	3.92%	0.00%	0.00%	0.00%	1.80%	3.61%
		Standard Few-shot	3.64%	5.83%	27.78%	4.25%	15.38%	11.37%	6.69%
		Naïve CoT Learning	7.96%	12.05%	8.33%	8.11%	6.25%	8.54%	8.75%
		Zero-Shot VSP	18.22%	12.37%	8.82%	2.27%	11.43%	10.62%	14.13%
		VSP Prompting	28.73%	24.27%	61.11%	6.38%	41.03%	32.30%	29.00%
		Other-Type VSP	28.83%	18.44%	5.56%	2.13%	12.82%	13.55%	21.24%
Llama2	SARD	Standard Prompt	90.82%	4.07%	0.00%	0.00%	3.08%	19.59%	43.40%
		Standard Few-shot	53.28%	37.33%	0.00%	0.00%	9.23%	19.98%	36.00%
		Naïve CoT Learning	93.88%	94.30%	62.50%	40.00%	24.61%	63.06%	74.40%
		Zero-Shot VSP	90.83%	4.89%	0.00%	0.00%	0.76%	19.29%	43.00%
		VSP Prompting	95.63%	57.72%	62.50%	40.00%	80.00%	67.17%	80.60%
		Other-Type VSP	80.00%	9.41%	28.57%	0.00%	18.28%	27.25%	44.15%
	CVE	Standard Prompt	43.07%	9.00%	13.89%	0.00%	0.00%	13.19%	26.38%
		Standard Few-shot	24.06%	15.15%	22.22%	8.51%	12.82%	16.55%	19.71%
		Naïve CoT Learning	40.23%	19.19%	25.00%	14.89%	25.64%	24.99%	31.21%
		Zero-Shot VSP	27.27%	2.00%	5.56%	0.00%	0.00%	6.96%	15.67%
		VSP Prompting	52.65%	33.33%	30.55%	38.29%	52.63%	41.49%	45.66%
		Other-Type VSP	27.65%	3.03%	2.78%	0.00%	0.00%	6.69%	15.91%
Falcon	SARD	Standard Prompt	0.44%	0.00%	0.00%	0.00%	0.00%	0.09%	0.20%
		Standard Few-shot	7.42%	2.44%	25.00%	0.00%	10.77%	9.13%	7.20%
		Naïve CoT Learning	2.88%	13.83%	0.00%	12.50%	33.94%	12.62%	14.32%
		Zero-Shot VSP	0.00%	0.81%	0.00%	0.00%	0.77%	0.32%	0.40%
		VSP Prompting	14.41%	80.49%	37.50%	40.00%	60.78%	46.63%	43.60%
		Other-Type VSP	6.99%	1.63%	0.00%	0.00%	3.08%	2.34%	4.40%
	CVE	Standard Prompt	0.75%	1.00%	0.00%	0.00%	0.00%	0.35%	0.61%
		Standard Few-shot	10.48%	5.00%	16.67%	4.26%	5.13%	8.31%	8.79%
		Naïve CoT Learning	5.99%	5.00%	0.00%	4.26%	25.64%	8.18%	6.75%
		Zero-Shot VSP	0.00%	0.00%	0.00%	0.00%	0.00%	0.00%	0.00%
		VSP Prompting	16.10%	25.00%	19.44%	21.28%	28.21%	22.01%	19.63%
		Other-Type VSP	3.00%	0.00%	0.00%	0.00%	0.00%	0.60%	1.64%

Table 12: Full vulnerability discovery effectiveness in terms of recall.

Model	Dataset	Strategy	CWE-787	CWE-125	CWE-476	CWE-416	CWE-190	Macro avg	Micro avg
GPT-3.5	SARD	Standard Prompt	52.75%	59.65%	85.71%	100.00%	34.48%	66.52%	53.56%
		Standard Few-shot	51.42%	54.32%	77.78%	60.00%	26.08%	53.92%	47.81%
		Naïve CoT Learning	48.28%	55.88%	100.00%	100.00%	27.27%	66.28%	50.19%
		Zero-Shot VSP	51.80%	38.36%	100.00%	100.00%	26.67%	63.36%	50.30%
		VSP Prompting	62.65%	60.95%	54.54%	50.00%	48.95%	55.42%	57.32%
		Other-Type VSP	53.31%	58.82%	45.45%	100.00%	46.12%	60.74%	52.63%
	CVE	Standard Prompt	48.27%	44.44%	0.00%	0.00%	0.00%	18.54%	46.15%
		Standard Few-shot	55.56%	31.58%	43.48%	50.00%	42.86%	44.69%	43.59%
		Naïve CoT Learning	42.11%	55.56%	66.67%	75.00%	50.00%	57.87%	49.25%
		Zero-Shot VSP	55.12%	38.71%	100.00%	50.00%	36.36%	56.04%	50.40%
		VSP Prompting	50.96%	49.01%	53.65%	60.00%	47.06%	52.14%	50.69%
		Other-Type VSP	56.02%	50.00%	20.00%	100.00%	45.45%	54.29%	52.73%
Llama2	SARD	Standard Prompt	53.75%	62.50%	0.00%	0.00%	100.00%	43.24%	54.39%
		Standard Few-shot	50.21%	44.66%	0.00%	0.00%	40.00%	26.97%	47.37%
		Naïve CoT Learning	49.19%	50.65%	45.45%	50.00%	48.48%	48.75%	49.53%
		Zero-Shot VSP	53.74%	50.00%	0.00%	0.00%	20.00%	24.75%	53.22%
		VSP Prompting	49.89%	48.63%	38.46%	50.00%	47.93%	46.98%	48.97%
		Other-Type VSP	52.46%	53.33%	66.67%	0.00%	62.96%	47.08%	53.63%
	CVE	Standard Prompt	53.24%	60.00%	55.56%	0.00%	0.00%	33.76%	53.75%
		Standard Few-shot	53.78%	48.39%	57.14%	40.00%	83.33%	56.53%	53.33%
		Naïve CoT Learning	52.97%	47.50%	52.94%	58.33%	55.56%	53.46%	52.59%
		Zero-Shot VSP	50.70%	50.00%	100.00%	0.00%	0.00%	40.14%	51.01%
		VSP Prompting	51.67%	51.56%	48.83%	48.65%	55.56%	50.65%	51.39%
		Other-Type VSP	47.40%	75.00%	50.00%	0.00%	0.00%	34.48%	47.53%
Falcon	SARD	Standard Prompt	50.00%	0.00%	0.00%	0.00%	0.00%	10.00%	50.00%
		Standard Few-shot	44.74%	23.08%	50.00%	0.00%	63.64%	36.29%	46.15%
		Naïve CoT Learning	29.41%	65.00%	0.00%	100.00%	61.67%	51.22%	57.14%
		Zero-Shot VSP	0.00%	100.00%	0.00%	0.00%	100.00%	40.00%	100.00%
		VSP Prompting	47.83%	51.56%	52.86%	66.67%	50.32%	51.85%	50.58%
		Other-Type VSP	57.14%	33.33%	0.00%	0.00%	57.14%	29.52%	53.66%
	CVE	Standard Prompt	100.00%	100.00%	0.00%	0.00%	0.00%	40.00%	100.00%
		Standard Few-shot	58.33%	71.43%	60.00%	22.22%	25.00%	47.39%	52.44%
		Naïve CoT Learning	34.04%	41.67%	0.00%	50.00%	58.82%	36.91%	39.29%
		Zero-Shot VSP	0.00%	0.00%	0.00%	0.00%	0.00%	0.00%	0.00%
		VSP Prompting	51.19%	58.14%	41.18%	40.00%	44.00%	46.90%	49.48%
		Other-Type VSP	66.67%	0.00%	0.00%	0.00%	0.00%	13.33%	66.67%

Table 13: Full vulnerability discovery effectiveness in terms of precision.

Model	Dataset	Strategy	CWE-787	CWE-125	CWE-476	CWE-416	CWE-190	Macro avg	Micro avg
GPT-3.5	SARD	Standard Prompt	64.75%	37.78%	80.00%	75.99%	12.57%	54.02%	51.50%
		Standard Few-shot	64.26%	56.14%	63.16%	37.50%	58.12%	55.19%	46.83%
		Naïve CoT Learning	63.12%	27.31%	84.21%	62.49%	5.29%	41.13%	34.08%
		Zero-Shot VSP	45.37%	24.20%	85.71%	46.15%	4.26%	48.49%	47.91%
		VSP Prompting	56.86%	43.14%	82.35%	72.00%	21.62%	55.83%	60.21%
		Other-Type VSP	63.10%	68.26%	52.63%	45.15%	56.54%	57.33%	62.19%
	CVE	Standard Prompt	9.21%	7.21%	0.00%	0.00%	0.00%	3.28%	6.70%
		Standard Few-shot	6.83%	9.83%	33.89%	7.84%	22.64%	16.21%	11.60%
		Naïve CoT Learning	13.39%	19.80%	14.81%	14.63%	11.11%	14.75%	14.86%
		Zero-Shot VSP	27.38%	18.75%	16.22%	4.34%	17.39%	16.81%	22.07%
		VSP Prompting	36.74%	32.47%	57.14%	11.54%	43.83%	36.34%	36.89%
		Other-Type VSP	38.07%	26.95%	8.69%	4.17%	20.00%	19.58%	30.28%
Llama2	SARD	Standard Prompt	67.53%	7.63%	0.00%	0.00%	5.97%	16.22%	48.27%
		Standard Few-shot	51.69%	40.71%	0.00%	0.00%	15.00%	21.48%	40.91%
		Naïve CoT Learning	64.56%	65.90%	52.63%	44.44%	32.65%	52.04%	59.47%
		Zero-Shot VSP	67.53%	8.89%	0.00%	0.00%	1.48%	15.58%	47.56%
		VSP Prompting	65.57%	52.79%	47.62%	44.44%	59.94%	54.07%	60.92%
		Other-Type VSP	63.37%	16.00%	40.00%	0.00%	28.33%	29.54%	48.44%
	CVE	Standard Prompt	47.62%	15.65%	22.22%	0.00%	0.00%	17.09%	35.39%
		Standard Few-shot	33.24%	23.07%	32.00%	14.04%	22.22%	24.92%	28.79%
		Naïve CoT Learning	45.72%	27.33%	33.96%	23.73%	35.09%	33.16%	39.17%
		Zero-Shot VSP	35.47%	3.85%	10.53%	0.00%	0.00%	9.96%	23.97%
		VSP Prompting	52.15%	40.49%	36.67%	42.86%	54.05%	45.25%	48.35%
		Other-Type VSP	34.93%	5.83%	5.26%	0.00%	0.00%	9.20%	23.83%
Falcon	SARD	Standard Prompt	0.87%	0.00%	0.00%	0.00%	0.00%	0.17%	0.39%
		Standard Few-shot	12.73%	4.41%	33.33%	0.00%	18.42%	13.78%	12.46%
		Naïve CoT Learning	5.24%	22.81%	0.00%	22.22%	43.79%	18.81%	22.90%
		Zero-Shot VSP	0.00%	1.61%	0.00%	0.00%	1.53%	0.63%	0.79%
		VSP Prompting	22.15%	62.86%	40.00%	50.00%	55.05%	46.01%	46.83%
		Other-Type VSP	12.45%	3.10%	0.00%	0.00%	5.84%	4.28%	8.13%
	CVE	Standard Prompt	1.49%	1.98%	0.00%	0.00%	0.00%	0.69%	1.22%
		Standard Few-shot	17.78%	9.35%	26.09%	7.14%	8.51%	13.77%	15.06%
		Naïve CoT Learning	10.19%	8.93%	0.00%	7.84%	35.71%	12.54%	11.52%
		Zero-Shot VSP	0.00%	0.00%	0.00%	0.00%	0.00%	0.00%	23.97%
		VSP Prompting	24.50%	34.97%	26.42%	27.78%	34.38%	29.61%	28.11%
		Other-Type VSP	5.73%	0.00%	0.00%	0.00%	0.00%	1.15%	3.19%

Table 14: Full vulnerability discovery effectiveness in terms of F1.

Model	Dataset	Strategy	CWE-787	CWE-125	CWE-416	CWE-476	CWE-190	Macro avg	Micro avg
GPT-3.5	SARD	Standard Prompting	64.29%	71.43%	0.00%	N/A	N/A	45.24%	65.88%
		Standard Few-Shot	98.21%	96.43%	0.00%	N/A	N/A	64.88%	96.47%
		Zero-Shot VSP	47.32%	42.86%	0.00%	N/A	N/A	30.06%	45.29%
		VSP Prompting	98.21%	96.43%	100.00%	N/A	N/A	98.21%	97.65%
		Other-Type VSP	92.86%	89.29%	0.00%	N/A	N/A	60.71%	90.59%
	CVE	Standard Prompting	13.04%	6.25%	0.00%	0.00%	0.00%	3.86%	8.24%
		Standard Few-Shot	13.04%	31.25%	25.00%	0.00%	7.69%	15.40%	15.29%
		Zero-Shot VSP	6.52%	6.25%	0.00%	0.00%	0.00%	2.55%	4.71%
		VSP Prompting	17.39%	25.00%	25.00%	0.00%	30.77%	19.63%	20.00%
		Other-Type VSP	6.52%	6.25%	0.00%	0.00%	7.69%	4.09%	5.88%
Llama2	SARD	Standard Prompting	15.18%	7.14%	0.00%	N/A	N/A	7.44%	12.35%
		Standard Few-Shot	9.82%	7.14%	0.00%	N/A	N/A	5.65%	8.82%
		Zero-Shot VSP	16.07%	17.86%	0.00%	N/A	N/A	11.31%	16.47%
		VSP Prompting	21.43%	17.86%	50.00%	N/A	N/A	29.76%	20.59%
		Other-Type VSP	12.50%	7.14%	0.00%	N/A	N/A	6.55%	10.59%
	CVE	Standard Prompting	4.35%	0.00%	0.00%	0.00%	0.00%	0.87%	2.35%
		Standard Few-Shot	8.70%	6.25%	0.00%	0.00%	46.15%	12.22%	12.94%
		Zero-Shot VSP	8.70%	18.75%	0.00%	0.00%	0.00%	5.49%	8.24%
		VSP Prompting	13.04%	25.00%	0.00%	0.00%	38.46%	15.30%	17.65%
		Other-Type VSP	6.52%	6.25%	0.00%	0.00%	15.38%	5.63%	7.06%
Falcon	SARD	Standard Prompting	0.00%	0.00%	0.00%	N/A	N/A	0.00%	0.00%
		Standard Few-Shot	0.00%	0.00%	0.00%	N/A	N/A	0.00%	0.00%
		Zero-Shot VSP	0.00%	0.00%	0.00%	N/A	N/A	0.00%	0.00%
		VSP Prompting	0.00%	0.00%	0.00%	N/A	N/A	0.00%	0.00%
		Other-Type VSP	0.00%	0.00%	0.00%	N/A	N/A	0.00%	0.00%
	CVE	Standard Prompting	0.00%	0.00%	0.00%	0.00%	0.00%	0.00%	0.00%
		Standard Few-Shot	0.00%	0.00%	0.00%	0.00%	0.00%	0.00%	0.00%
		Zero-Shot VSP	0.00%	0.00%	0.00%	0.00%	0.00%	0.00%	0.00%
		VSP Prompting	0.00%	0.00%	0.00%	0.00%	0.00%	0.00%	0.00%
		Other-Type VSP	0.00%	0.00%	0.00%	0.00%	0.00%	0.00%	0.00%

Table 15: Full vulnerability patching effectiveness in terms of accuracy.

CWE ID	Project	CVE ID	VSP Prompting	Standard Prompting
CWE787	linux	2023-3090	failed	failed
CWE787	libtiff	2023-30775	failed	failed
CWE787	libjpeg	2023-2804	failed	failed
CWE787	gpac	2023-4754	failed	failed
CWE787	nettle	2023-36660	correct	failed
CWE787	linux	2023-35788	correct	failed
CWE787	radare	2023-4322	failed	correct
CWE787	libjpeg	2023-37837	correct	failed
CWE787	chrome	2023-4863	correct	correct
CWE787	libx11	2023-3138	failed	failed
CWE787	linux	2023-2124	failed	failed
CWE787	linux	2023-31436	failed	failed
CWE787	linux	2023-3812	failed	correct
CWE787	linux	2023-3090	failed	failed
CWE787	libx11	2023-3138	failed	failed
CWE787	linux	2023-3611	failed	failed
CWE125	libcoap	2023-35862	failed	failed
CWE125	linux	2023-38432	failed	failed
CWE125	bzip3	2023-29418	failed	failed
CWE125	bzip3	2023-29419	failed	failed
CWE125	linux	2023-38427	failed	correct
CWE125	linux	2023-3268	failed	failed
CWE125	linux	2023-38428	correct	correct
CWE125	gpac	2023-4721	correct	failed
CWE125	linux	2023-34256	correct	failed
CWE125	linux	2023-38431	correct	failed
CWE125	linux	2023-38426	correct	correct
CWE125	gpac	2023-3523	correct	failed
CWE125	gpac	2023-4778	correct	failed
CWE476	vim	2023-2609	failed	failed
CWE476	linux	2023-3358	failed	failed
CWE476	linux	2023-4459	correct	failed
CWE476	linux	2023-3359	failed	failed
CWE476	linux	2023-3355	correct	failed
CWE476	gpac	2023-4681	correct	failed
CWE476	linux	2023-3358	correct	failed
CWE476	linux	2023-32248	failed	failed
CWE476	linux	2023-4385	correct	failed
CWE416	linux	2023-4244	failed	failed
CWE416	gpac	2023-4755	correct	failed
CWE416	vim	2023-4752	failed	failed
CWE416	linux	2023-4387	failed	failed
CWE416	linux	2023-4622	failed	failed
CWE190	freerdp	2023-40186	failed	failed
CWE190	vim	2023-2610	failed	failed
CWE190	libtommath	2023-36328	correct	failed
CWE190	NTSC-CRT	2023-39125	correct	failed
CWE190	garmin	2023-23298	correct	correct
CWE190	vim	2023-4722	failed	failed
CWE190	sysstat	2023-33204	correct	correct
CWE190	rizin	2023-40022	correct	correct
CWE190	sofia-sip	2023-32307	failed	failed
CWE190	vim	2023-4734	failed	failed
CWE190	android	2023-35681	failed	failed
CWE787	chrome	2023-5217	failed	failed

Table 16: Latest vulnerabilities discovered by VSP prompting and standard prompting.

```

1 int avpriv_ac3_parse_header(AC3HeaderInfo **phdr,
2     const uint8_t *buf, size_t size){
3     GetBitContext gb;
4     AC3HeaderInfo *hdr;
5     int err;
6     hdr = *phdr;
7     // Initialize `&gb`. If failed, &gb will still be NULL.
8     init_get_bits8(&gb, buf, size);
9     // Parse the header `&gb`.
10    err = ff_ac3_parse_header(&gb, hdr);
11    if (err < 0)
12        return AVERROR_INVALIDDATA;
13    return get_bits_count(&gb);
14}

```

Answer without comments:

A: CWE-476 is NULL pointer dereference. Thus, the part that is mostly likely to have CWE-476 vulnerability is the dereference of pointers:

...

```
err = ff_ac3_parse_header(&gb, hdr);
```

...

Looking at the contexts of the code, `init\_get\_bits8(&gb, buf, size);` guarantees that the pointer `&gb` is not NULL.

Therefore, the code does not have a CWE-476 vulnerability.

Answer with comments:

A: CWE-476 is NULL pointer dereference. Thus, the part that is mostly likely to have CWE-476 vulnerability is the dereference of pointers:

...

```
err = ff_ac3_parse_header(&gb, hdr);
```

...

Looking at the contexts of the code, there is no guarantee that the pointer `&gb` is not NULL.

Therefore, the code has a CWE-476 vulnerability.

Figure 5: An example that telling the model the contexts by adding comments helps the model do correct analysis.

//Exemplars with questions behind the code like this.

Q: Given the following code:

// Code for "CWE125_Buffer_Underread__malloc_wchar_t_ncpy_14_vul.c"

Does the code above have CWE-125 out-of-bound read vulnerability? Please focus on the part that is most likely to have the vulnerability.

Answer with original VSFP prompt:

A: CWE-125 is out-of-bounds read. Thus, the part that is mostly likely to have CWE-125 vulnerability is the read of the buffers:

...

wcsncpy(dest, data, wcslen(dest));

...

Looking at the contexts of the code, `if (globalFive == 5)` guarantees that the pointer `data` is not NULL, otherwise the code inside the if statement will not be executed.

Therefore, the code does not have a CWE-125 vulnerability.

Answer with modified VSFP prompt:

A: CWE-125 is out-of-bounds read. Thus, the part that is mostly likely to have CWE-125 vulnerability is the read of the buffers:

...

wcsncpy(dest, data, wcslen(dest));

...

Looking at the contexts of the code, `data` is assigned `dataBuffer - 8`, which means `data` is pointing to a location 8 elements before the start of `dataBuffer`. This can lead to reading out-of-bounds memory if `dataBuffer` is not large enough

Therefore, the code has a CWE-125 vulnerability.

Figure 6: An example that moving the question behind the code and telling the CWE ID meaning help prevent oblivion of CWE.